

Chapter 8

Network Security

A note on the use of these ppt slides:

We're making these slides freely available to all (faculty, students, readers). They're in PowerPoint form so you can add, modify, and delete slides (including this one) and slide content to suit your needs. They obviously represent a *lot* of work on our part. In return for use, we only ask the following:

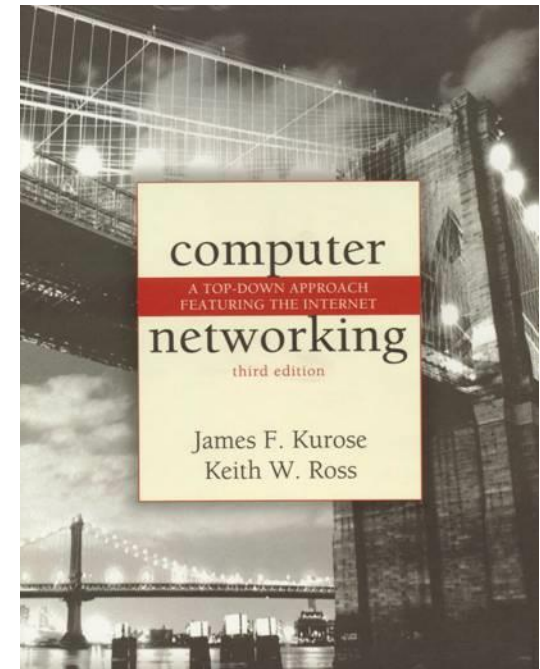
If you use these slides (e.g., in a class) in substantially unaltered form, that you mention their source (after all, we'd like people to use our book!)

If you post any slides in substantially unaltered form on a www site, that you note that they are adapted from (or perhaps identical to) our slides, and note our copyright of this material.

Thanks and enjoy! JFK/KWR

All material copyright 1996-2004

J.F Kurose and K.W. Ross, All Rights Reserved



Jim
Kurose
Keith
Ross

3rd edition.

Jim Kurose, Keith Ross
Addison-Wesley, July
2004.

Chapter 8: Network Security

Chapter goals:

- r understand principles of network security:
 - m cryptography and its uses beyond “confidentiality”
 - m authentication
 - m message integrity
 - m key distribution
- r security in practice:
 - m firewalls
 - m security in application, transport, network, link layers

Chapter 8 roadmap

8.1 What is network security?

8.2 Principles of cryptography

8.3 Authentication

8.4 Integrity

8.5 Key Distribution and certification

8.6 Access control: firewalls

8.7 Attacks and counter measures

8.8 Security in many layers

What is network security?

Confidentiality: only sender, intended receiver should “understand” message contents

- m sender encrypts message

- m receiver decrypts message

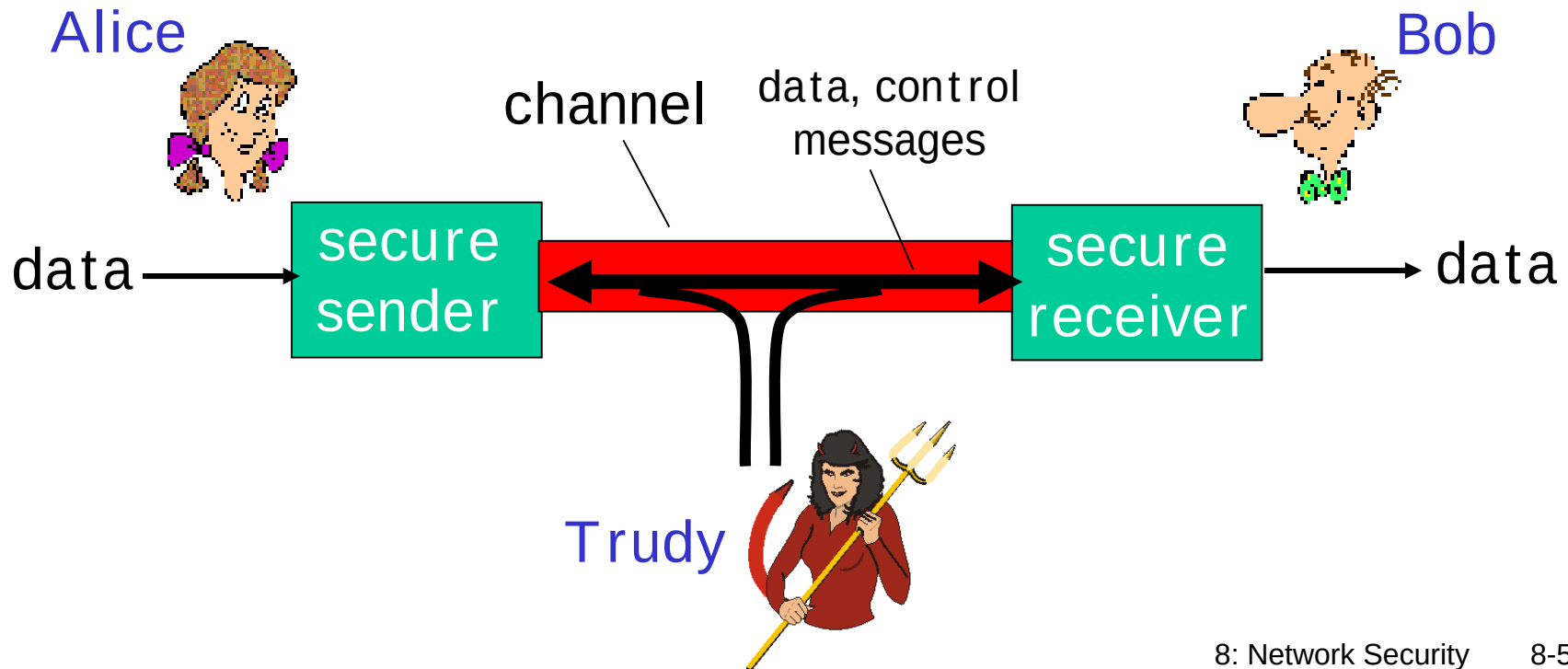
Authentication: sender, receiver want to confirm identity of each other

Message Integrity: sender, receiver want to ensure message not altered (in transit, or afterwards) without detection

Access and Availability: services must be accessible and available to users

Friends and enemies: Alice, Bob, Trudy

- r well-known in network security world
- r Bob, Alice (lovers!) want to communicate “securely”
- r Trudy (intruder) may intercept, delete, add messages



Who might Bob, Alice be?

- r ... well, ~~a~~ - ~~E~~ Bobs and Alices!
- r Web browser/server for electronic transactions (e.g., on-line purchases)
- r on-line banking client/server
- r DNS servers
- r routers exchanging routing table updates
- r other examples?

There are bad guys (and girls) out there!

Q: What can a “bad guy” do?

A: a lot!

- m ~~can~~ intercept messages
- m actively ~~inject~~ messages into connection
- m ~~can~~ can fake (spoof) source address in packet (or any field in packet)
- m ~~can~~ “take over” ongoing connection by removing sender or receiver, inserting himself in place
- m ~~can~~ : prevent service from being used by others (e.g., by overloading resources)

m o r e o n t h i s l a t e r

Chapter 8 roadmap

8.1 What is network security?

8.2 Principles of cryptography

8.3 Authentication

8.4 Integrity

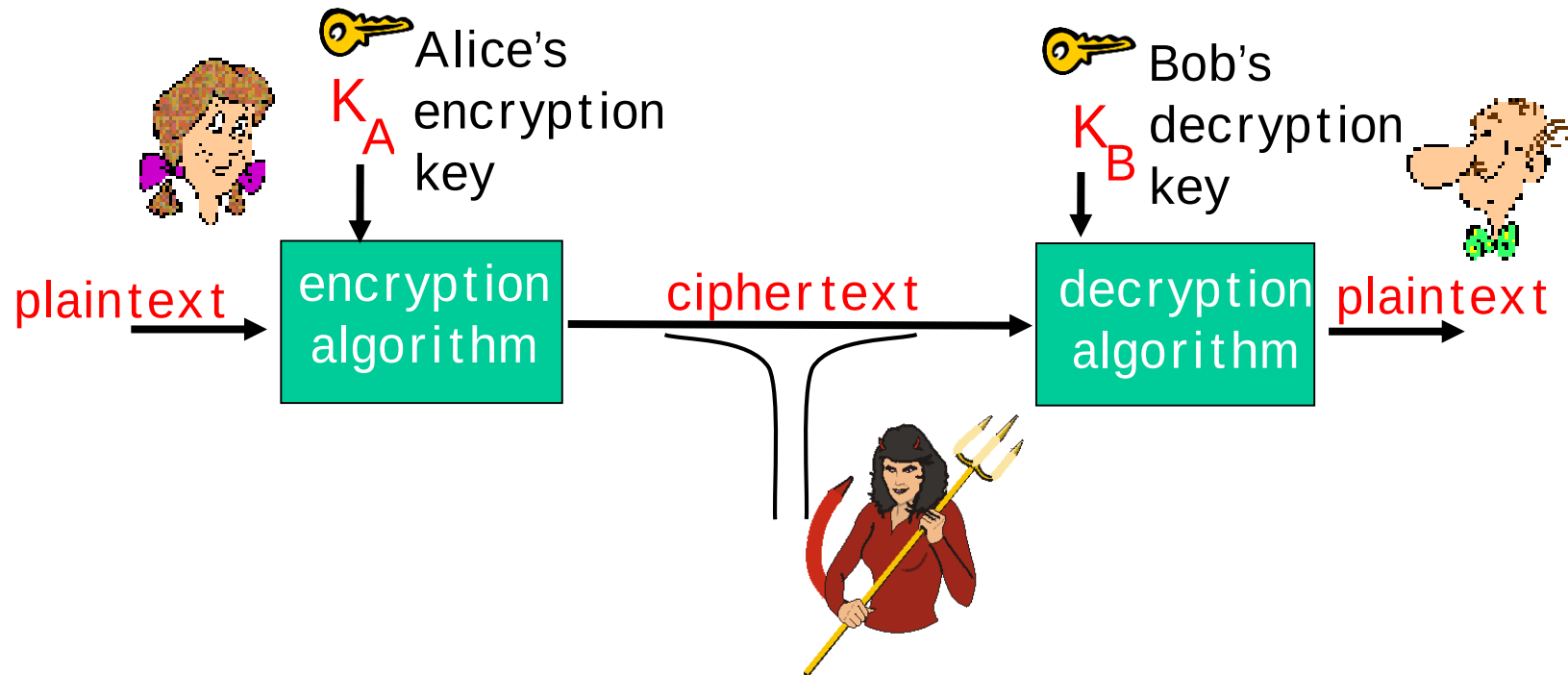
8.5 Key Distribution and certification

8.6 Access control: firewalls

8.7 Attacks and counter measures

8.8 Security in many layers

The language of cryptography



symmetric key crypto: sender, receiver keys k

public-key crypto: encryption key p , decryption key d
(private)

Symmetric key cryptography

substitution cipher: substituting one thing for another

m monoalphabetic cipher: substitute one letter for another

plaintext: **abcdefghijklmnopqrstuvwxyz**

ciphertext: **mnbvcxz asdfghjklpoiuytrewq**

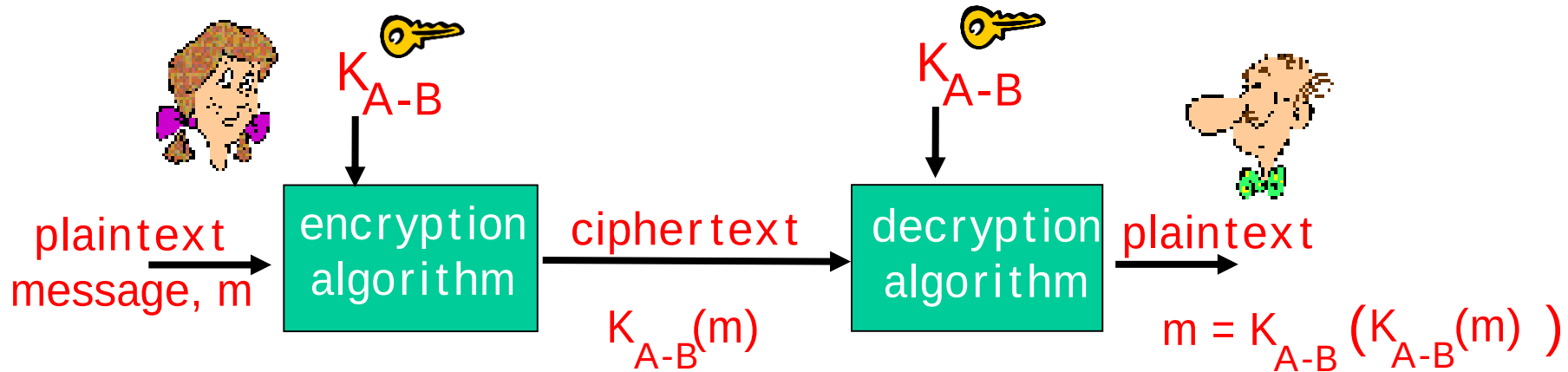
E.g.: Plaintext: bob. i love you. alice
ciphertext: nkn. s gktc wky. mgsbc

Q: How hard to break this simple cipher?:

brute force (how hard?)

other?

Symmetric key cryptography



symmetric key crypto: Bob and Alice share know same (symmetric) key: K_{A-B}

r e.g., key is knowing substitution pattern in mono alphabetic substitution cipher

r Q: how do Bob and Alice agree on key value?

Symmetric key crypto: DES

DES: Data Encryption Standard

- r US encryption standard [NIST 1993]
- r 56-bit symmetric key, 64-bit plaintext input
- r How secure is DES?
 - m DES Challenge: 56-bit-key-encrypted phrase (“Strong cryptography makes the world a safer place”) decrypted (brute force) in 4 months
 - m no known “backdoor” decryption approach
- r making DES more secure:
 - m use three keys sequentially (3-DES) on each datum
 - m use cipher-block chaining

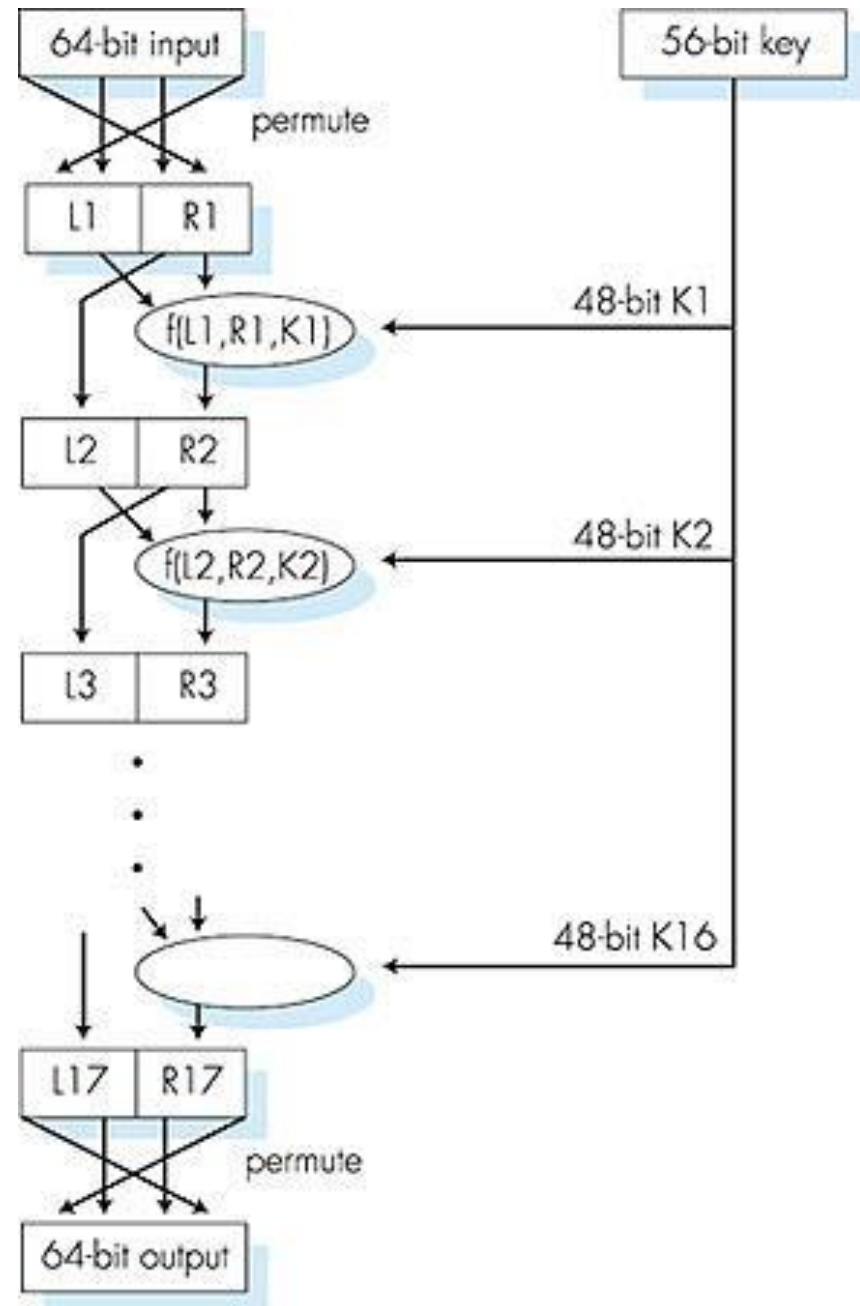
Symmetric key crypto: DES

DES operation

initial permutation

16 identical “rounds” of
function application,
each using different
48 bits of key

final permutation



AES: Advanced Encryption Standard

- r new (Nov. 2001) symmetric-key NIST standard, replacing DES
- r processes data in 128 bit blocks
- r 128, 192, or 256 bit keys
- r brute force decryption (try each key)
taking 1 sec on DES, takes 149 trillion years for AES

Public Key Cryptography

~~h~~ key crypto

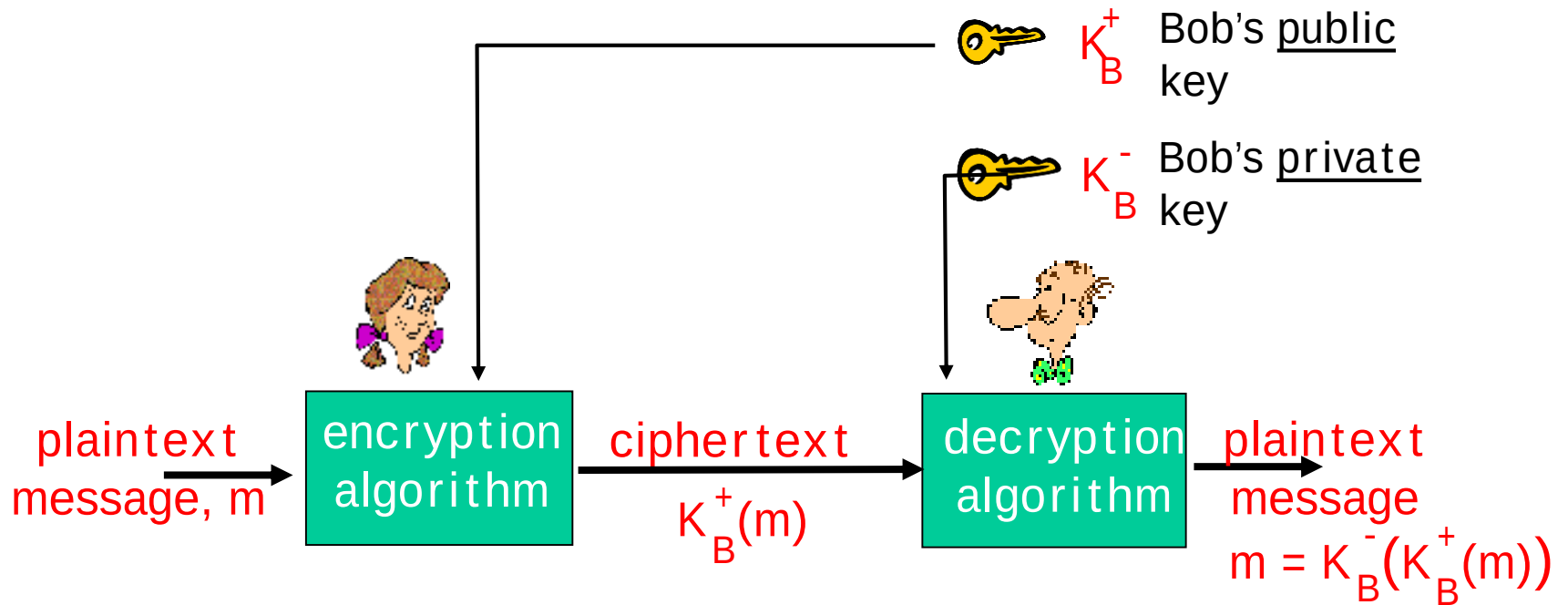
- r requires sender, receiver know shared secret key
- r Q: how to agree on key in first place (particularly if never “met”)?

~~h~~ key cryptography

- r radically different approach [Diffie-Hellman76, RSA78]
- r sender, receiver do
 - ~~h~~ share secret key
- r ~~h~~ encryption key known to ~~h~~
- r ~~h~~ decryption key known only to receiver



Public key cryptography



Public key encryption algorithms

Requirements:

- ① need $K_B^+(\cdot)$ and $K_B^-(\cdot)$ such that

$$K_B^-(K_B^+(m)) = m$$

- ② given public key K_B^+ , it should be impossible to compute private key K_B^-

RSA: Rivest, Shamir, Adelson algorithm

RSA: Choosing keys

1. Choose two large prime numbers p and q (e.g., 1024 bits each)
2. Compute $n = pq$ and $\phi = (p-1)(q-1)$
3. Choose e (with e that has no common factors with ϕ are “relatively prime”).
4. Choose d such that $ed - 1$ is exactly divisible by ϕ . (in other words: $ed \bmod \phi = 1$).
5. The key is (e, n) for encryption and (d, n) for decryption.
 $\underbrace{(e, n)}_{K_B^+}$ $\underbrace{(d, n)}_{K_B^-}$

RSA: Encryption, decryption

0. Given (p) and (q) as computed above
1. To encrypt bit pattern, m , compute
 $c = m^e \bmod n$ (i.e., remainder when m^e is divided by n)
2. To decrypt received bit pattern, c , compute
 $m = c^d \bmod n$ (i.e., remainder when c^d is divided by n)

Magic
happens!

$$m = (n \quad \underbrace{e \bmod n}_c)^d \bmod n$$

RSA example:

Bob chooses ~~5~~ p . Then ~~17~~ q .
 z (so e relatively prime).
 d (so $ed - 1$ exactly divisible by z).

encrypt:	<u>letter</u>	<u>m</u>	<u>m^e</u>	<u>c = m^e mod n</u>
	I	12	1524832	17
decrypt:	<u>c</u>	<u>c^d</u>	<u>m = c^d mod n</u>	<u>letter</u>
	17	481968572106750915091411825223071697	12	I

RSA: Why is that $m \equiv m^{e \bmod \phi(n)} d \bmod n$

Useful number theory result: If p prime and $m \not\equiv 0 \pmod p$ then:
 $x^y \bmod p \equiv x^{y \bmod (p-1)} \bmod p$

$$\begin{aligned} m^{e \bmod \phi(n)} d \bmod n &= m^d \bmod n \\ &= m^{d \bmod (p-1)} \bmod n \\ &\quad \text{(using number theory result above)} \\ &= m^1 \bmod n \\ &\quad \text{(since we chose } d \text{ to be divisible by } p-1 \text{ with remainder 1)} \\ &= m \end{aligned}$$

RSA: another important property

The following property will be ~~useful~~ useful later:

$$\underbrace{K_B^-(K_B^+(m))}_{\text{use public key first, followed by private key}} = m = \underbrace{K_B^+(K_B^-(m))}_{\text{use private key first, followed by public key}}$$

use public key
first, followed
by private key

use private key
first, followed
by public key

~~listen~~

Chapter 8 roadmap

8.1 What is network security?

8.2 Principles of cryptography

8.3 Authentication

8.4 Integrity

8.5 Key Distribution and certification

8.6 Access control: firewalls

8.7 Attacks and counter measures

8.8 Security in many layers

Authentication

Goal: Bob wants Alice to “prove” her identity to him

Protocol ap1.0: Alice says “I am Alice”



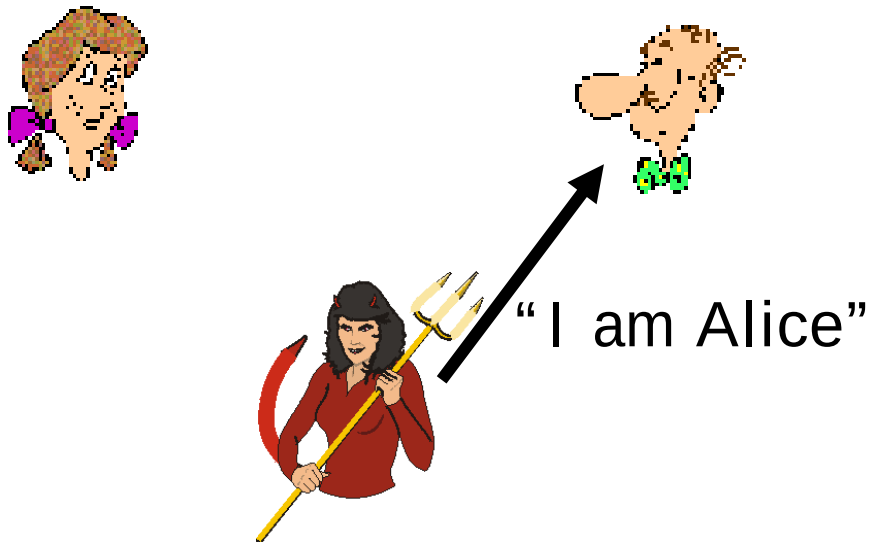
Failure scenario??



Authentication

Goal: Bob wants Alice to “prove” her identity to him

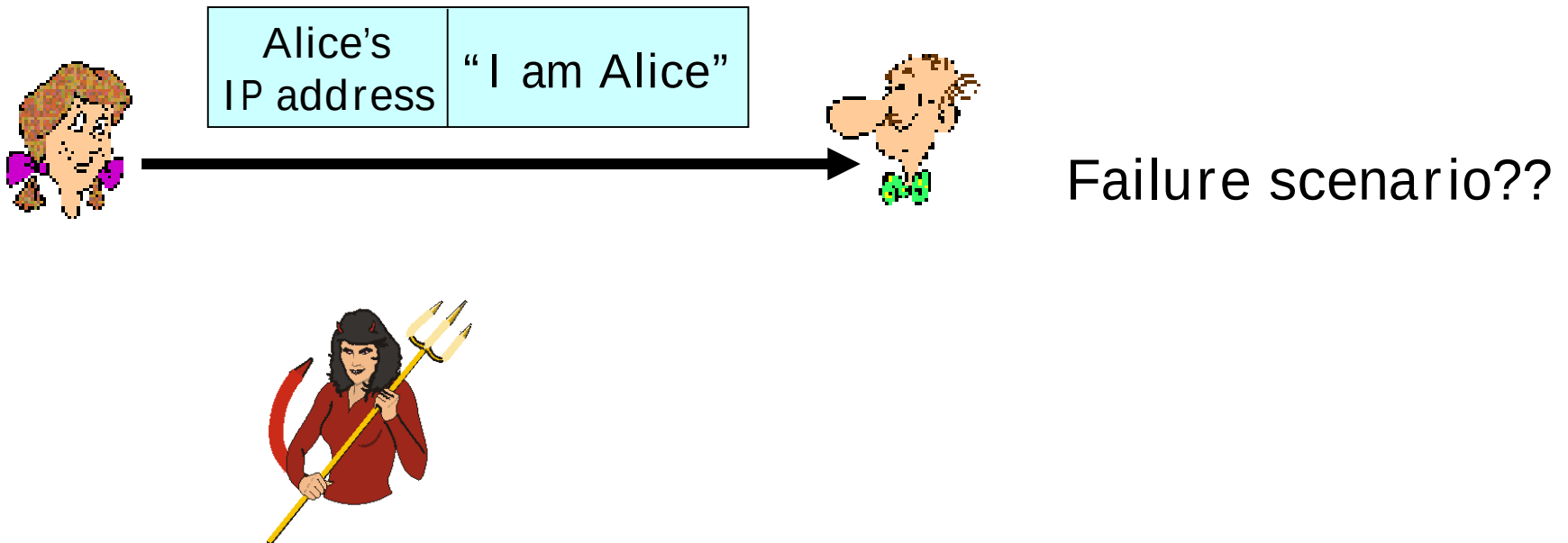
Protocol ap1.0: Alice says “I am Alice”



in a network,
Bob can not “see”
Alice, so Trudy simply
declares
herself to be Alice

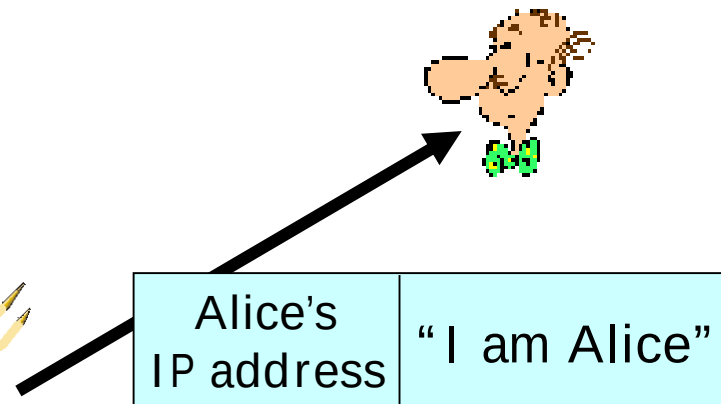
Authentication: another try

Protocol ap2.0: Alice says “I am Alice” in an IP packet containing her source IP address



Authentication: another try

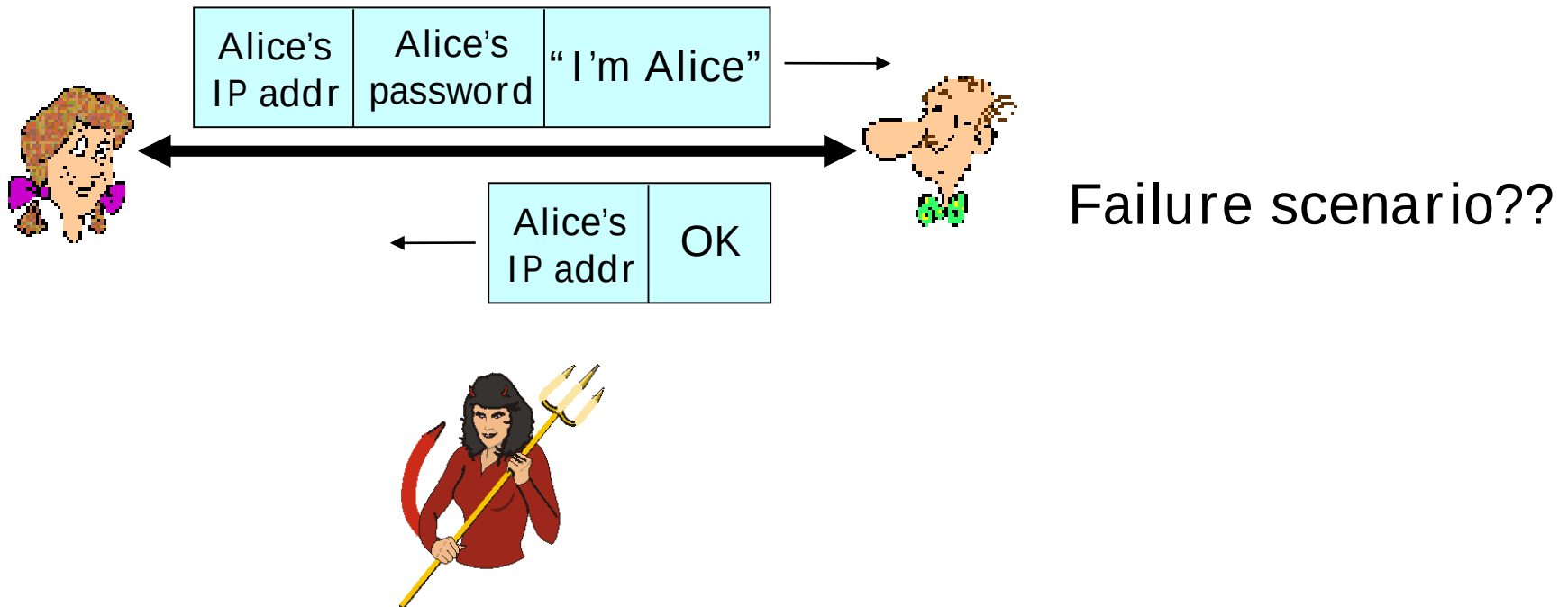
Protocol ap2.0: Alice says “I am Alice” in an IP packet containing her source IP address



Trudy can create
a packet
“spoofing”
Alice’s address

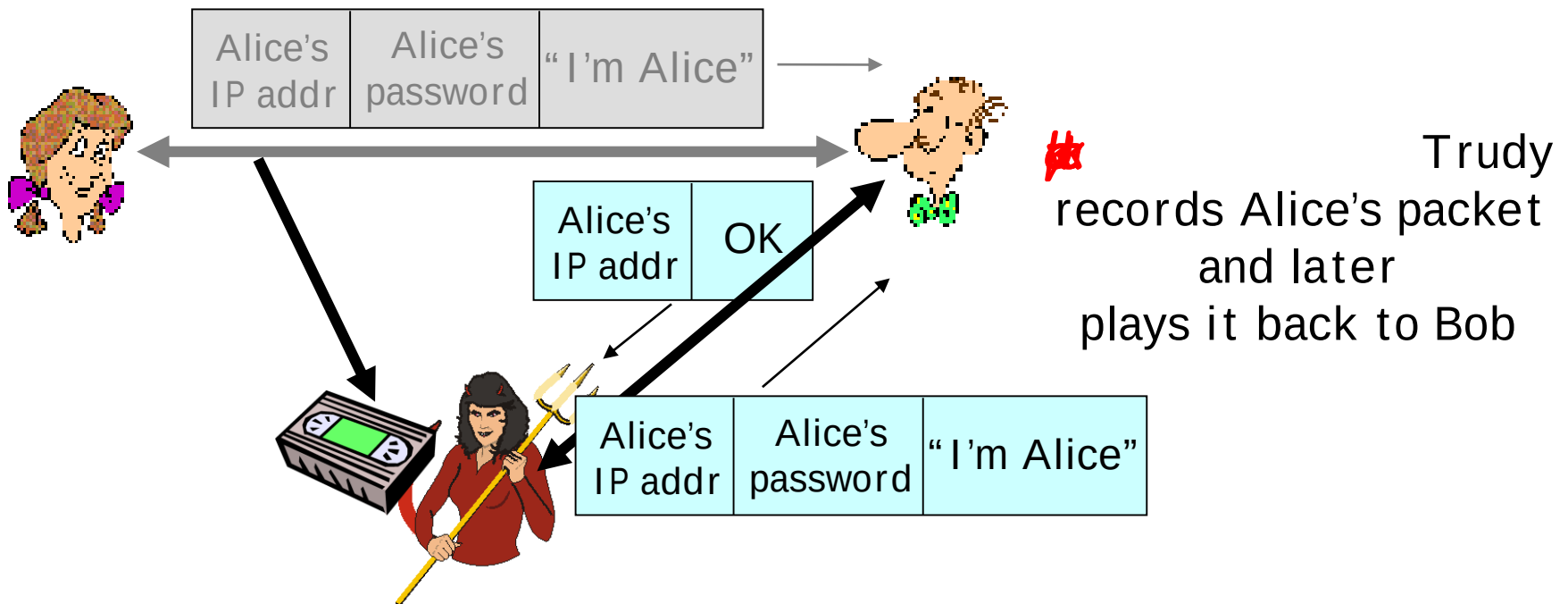
Authentication: another try

Protocol ap3.0: Alice says “I am Alice” and sends her secret password to “prove” it.



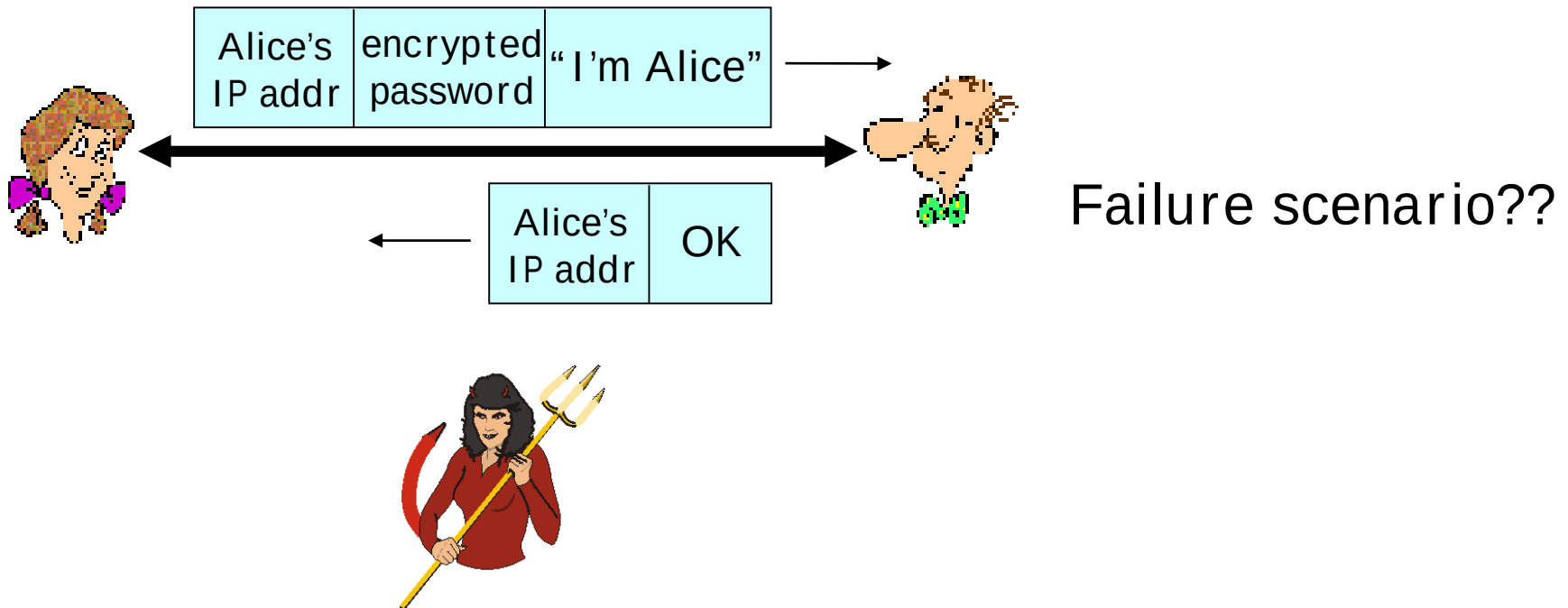
Authentication: another try

Protocol ap3.0: Alice says “I am Alice” and sends her secret password to “prove” it.



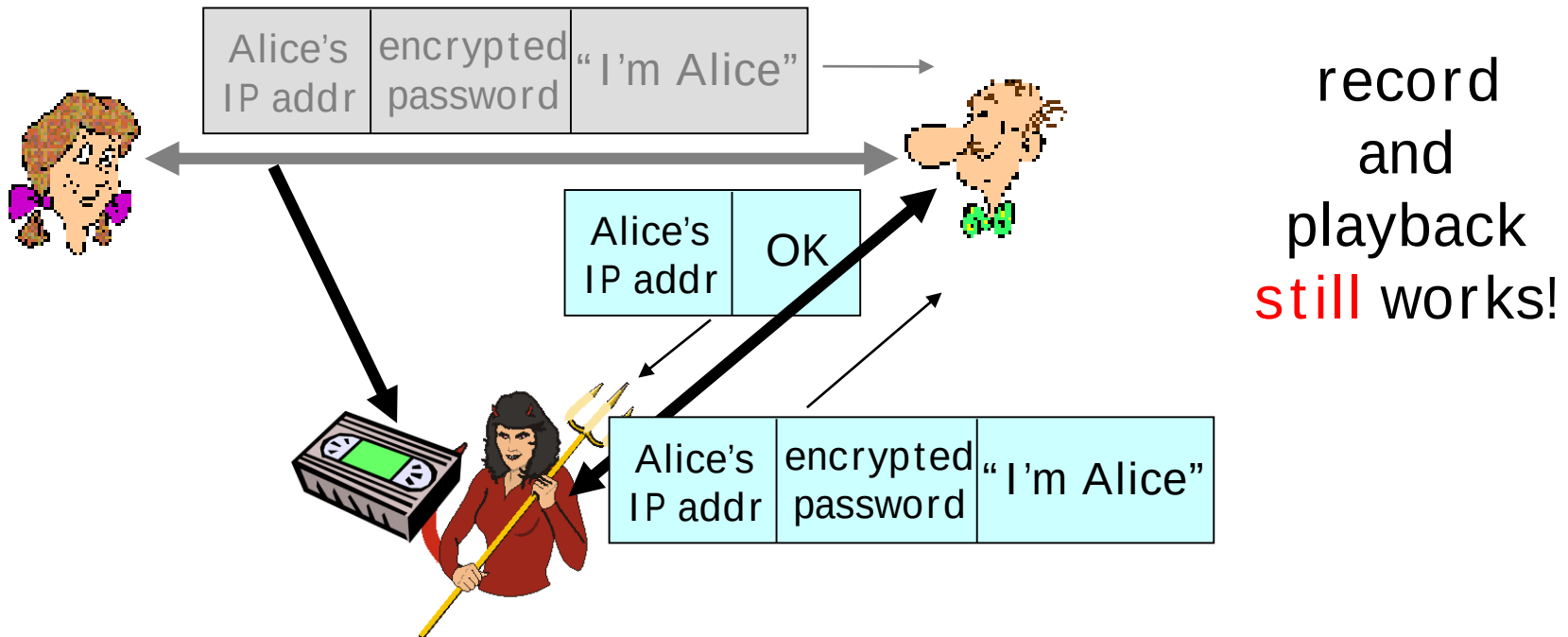
Authentication: yet another try

Protocol ap3.1: Alice says “I am Alice” and sends her secret password to “prove” it.



Authentication: another try

Protocol ap3.1: Alice says “I am Alice” and sends her secret password to “prove” it.

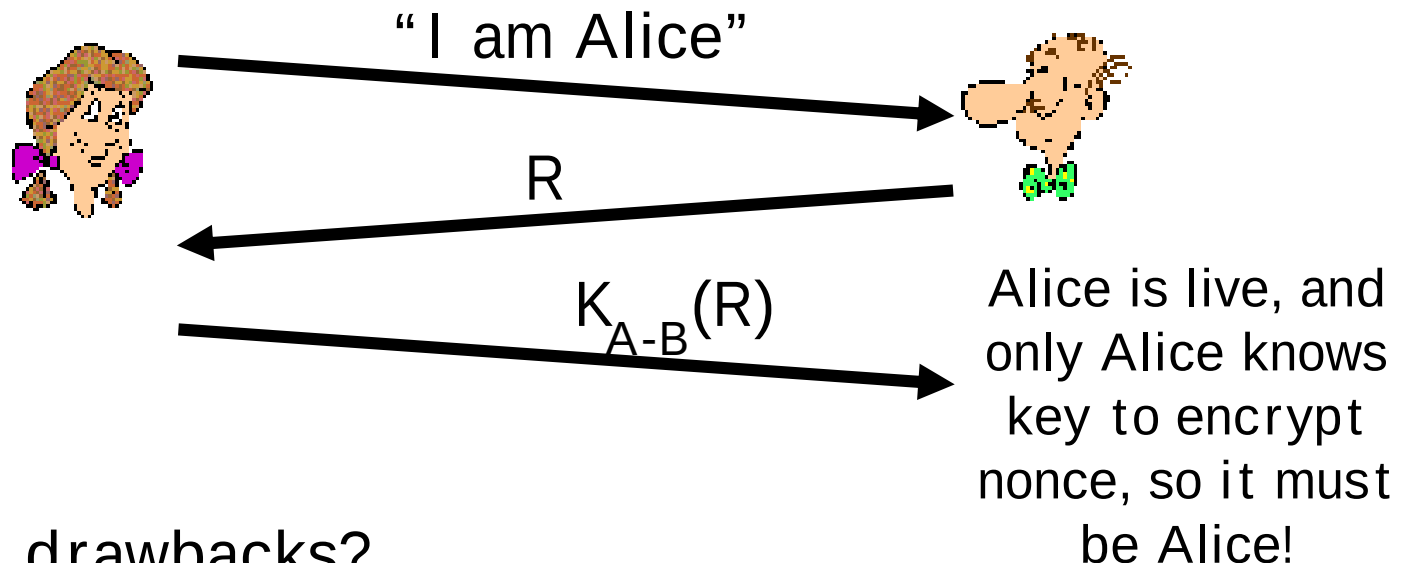


Authentication: yet another try

Goal: avoid playback attack

Nonce: number (R) used only ~~a~~ ~~-n -a-~~

ap4.0: to prove Alice “live”, Bob sends Alice **nonce**, R. Alice must return R, encrypted with shared secret key



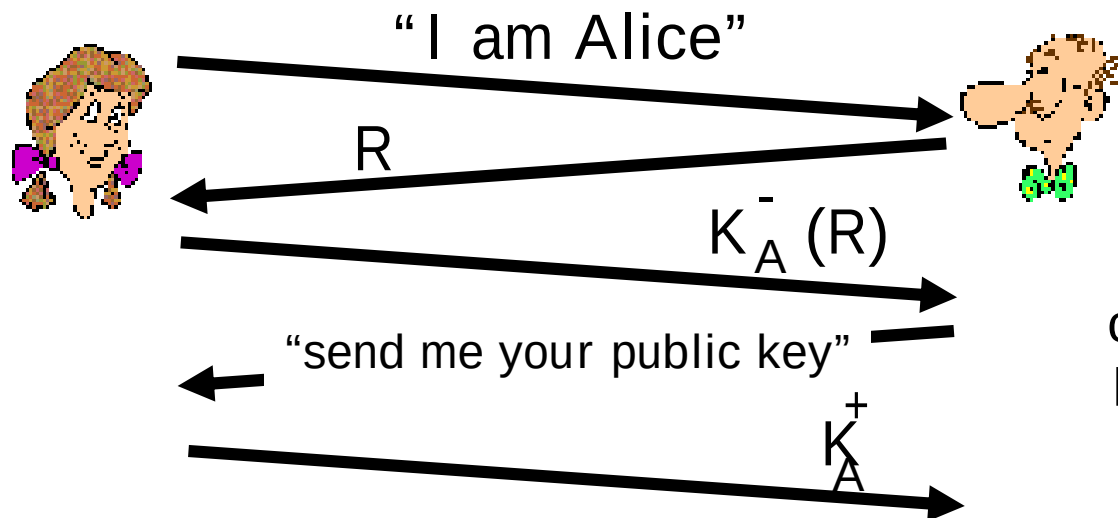
Failures, drawbacks?

Authentication: ap5.0

ap4.0 requires shared symmetric key

r can we authenticate using public key techniques?

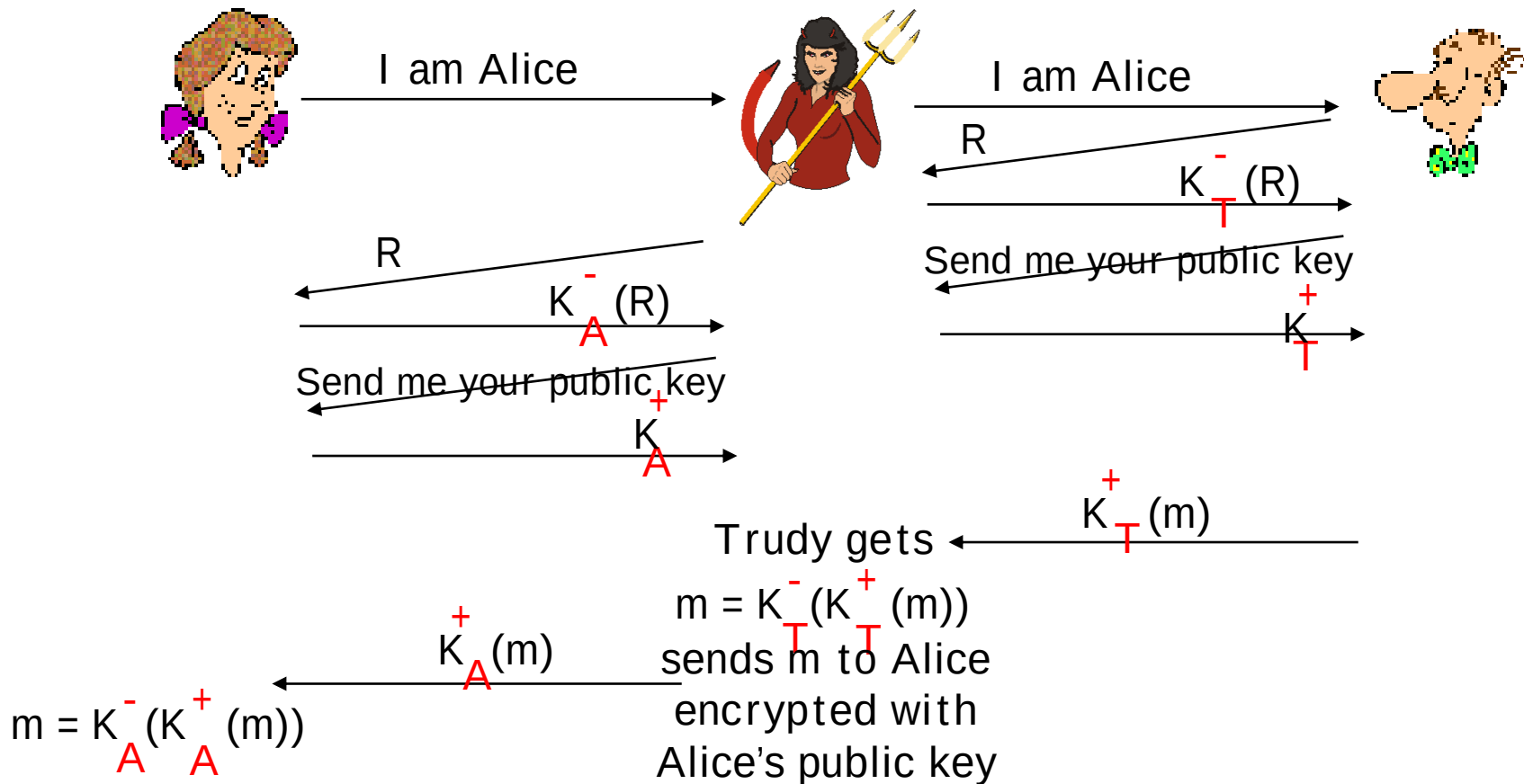
ap5.0: use nonce, public key cryptography



Bob computes
 $K_A^+(K_A^-(R)) = R$
and knows only Alice
could have the private
key, that encrypted R
such that
 $K_A^+(K_A^-(R)) = R$

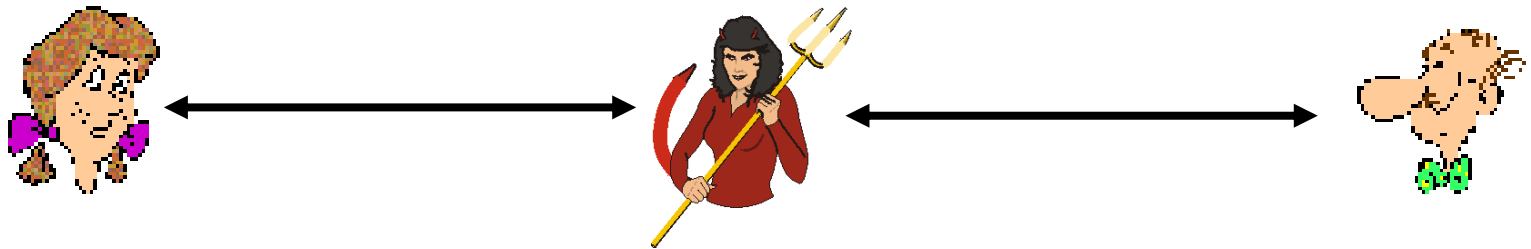
ap5.0: security hole

Man (woman) in the middle attack: Trudy poses as Alice (to Bob) and as Bob (to Alice)



ap5.0: security hole

Man (woman) in the middle attack: Trudy poses as Alice (to Bob) and as Bob (to Alice)



Difficult to detect:

Bob receives everything that Alice sends, and vice versa. (e.g., so Bob, Alice can meet one week later and recall conversation)

problem is that Trudy receives all messages as well!

Chapter 8 roadmap

8.1 What is network security?

8.2 Principles of cryptography

8.3 Authentication

8.4 Message integrity

8.5 Key Distribution and certification

8.6 Access control: firewalls

8.7 Attacks and counter measures

8.8 Security in many layers

Digital Signatures

Cryptographic technique analogous to handwritten signatures.

- r sender (Bob) digitally signs document, establishing he is document owner/creator.
- r **verifiable, nonforgeable**: recipient (Alice) can prove to someone that Bob, and no one else (including Alice), must have signed document

Digital Signatures

Simple digital signature for message m :

- Bob signs m by encrypting with his private key K_B^- , creating “signed” message, $K_B^-(m)$

Bob's message, m

Dear Alice
Oh, how I have missed
you. I think of you all the
time! ... (blah blah blah)
Bob



K_B^- Bob's private
key

Public key
encryption
algorithm

$K_B^-(m)$

Bob's message,
 m , signed
(encrypted) with
his private key

Digital Signatures (more)

- r Suppose Alice receives msg m , digital signature $K_B^-(m)$
- r Alice verifies m signed by Bob by applying Bob's public key K_B^+ to $K_B^-(m)$ then checks $K_B^+(K_B^-(m)) = m$.
- r If $K_B^+(K_B^-(m)) = m$, whoever signed m must have used Bob's private key.

Alice thus verifies that:

- ü Bob signed m .
- ü No one else signed m .
- ü Bob signed m and not m' .

Non-repudiation:

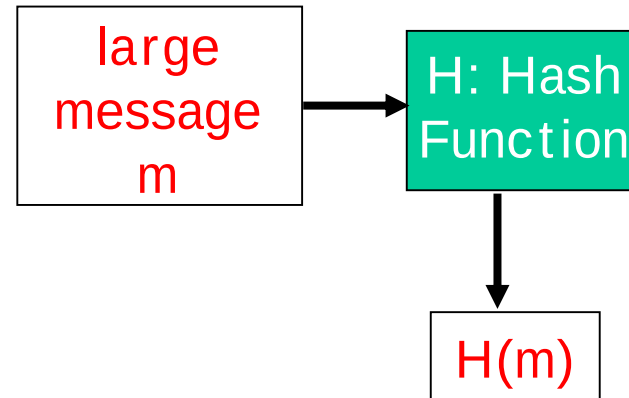
- ü Alice can take m , and signature $K_B^-(m)$ to court and prove that Bob signed m .

Message Digests

Computationally expensive
to public-key-encrypt
long messages

Goal: fixed-length, easy-
to-compute digital
“fingerprint”

- r apply hash function H
to m , get fixed size
message digest, ~~H~~



Hash function properties:

- r many-to-1
- r produces fixed-size msg
digest (fingerprint)
- r given message digest x ,
computationally
infeasible to find m such
that $x = H(m)$

Internet checksum: poor crypto hash function

Internet checksum has some properties of hash function:

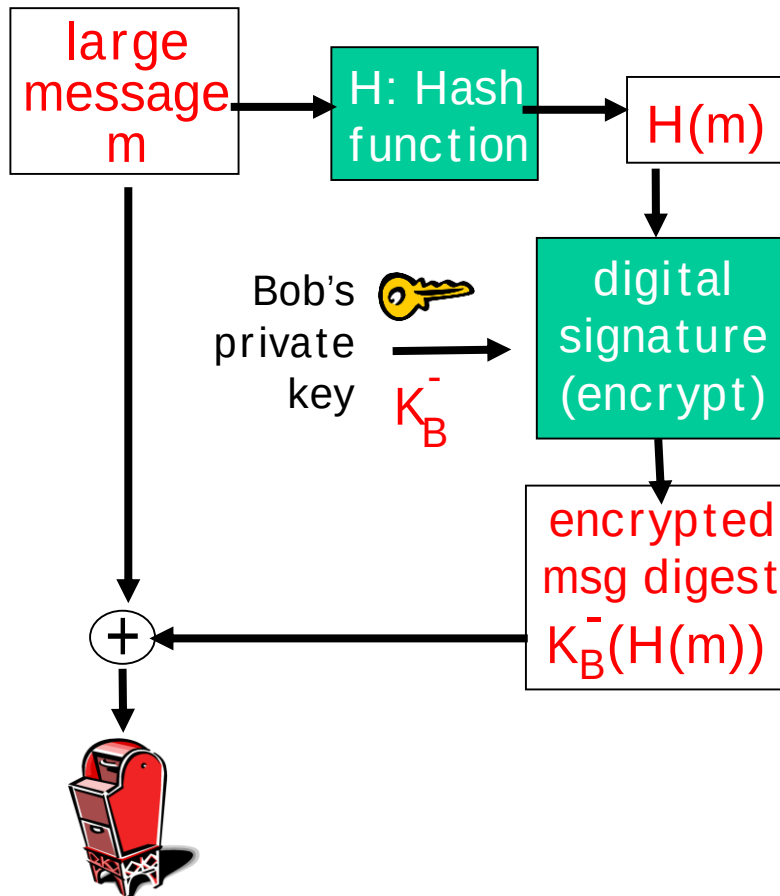
- ü produces fixed length digest (16-bit sum) of message
- ü is many-to-one

But given message with given hash value, it is easy to find another message with same hash value:

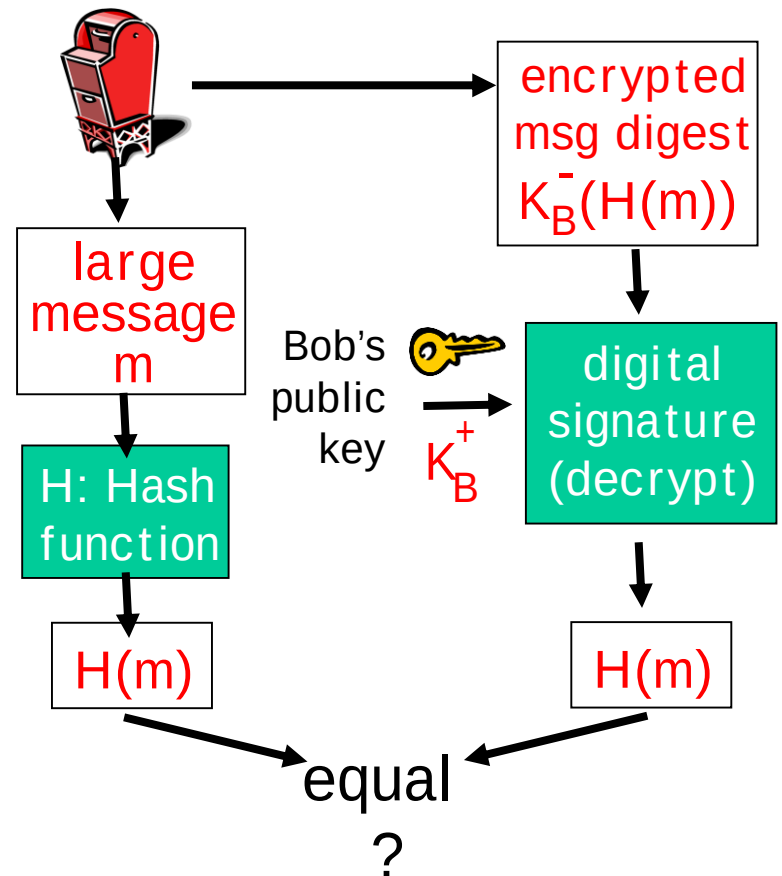
<u>message</u>	<u>ASCII format</u>		<u>message</u>	<u>ASCII format</u>
I O U 1	49 4F 55 31		I O U <u>9</u>	49 4F 55 <u>39</u>
0 0 . 9	30 30 2E 39		0 0 . <u>1</u>	30 30 2E <u>31</u>
9 B 0 B	39 42 D2 42		9 B 0 B	39 42 D2 42
<u>B2 C1 D2 AC</u>		different messages but identical checksums!	<u>B2 C1 D2 AC</u>	

Digital signature = signed message digest

Bob sends digitally signed message:



Alice verifies signature and integrity of digitally signed message:



Hash Function Algorithms

- r MD5 hash function widely used (RFC 1321)
 - m computes 128-bit message digest in 4-step process.
 - m arbitrary 128-bit string x , appears difficult to construct msg m whose MD5 hash is equal to x .
- r SHA-1 is also used.
 - m US standard [NIST, FIPS PUB 180-1]
 - m 160-bit message digest

Chapter 8 roadmap

8.1 What is network security?

8.2 Principles of cryptography

8.3 Authentication

8.4 Integrity

8.5 Key distribution and certification

8.6 Access control: firewalls

8.7 Attacks and counter measures

8.8 Security in many layers

Trusted Intermediaries

Symmetric key problem:

- r How do two entities establish shared secret key over network?

Solution:

- r trusted key distribution center (KDC) acting as intermediary between entities

Public key problem:

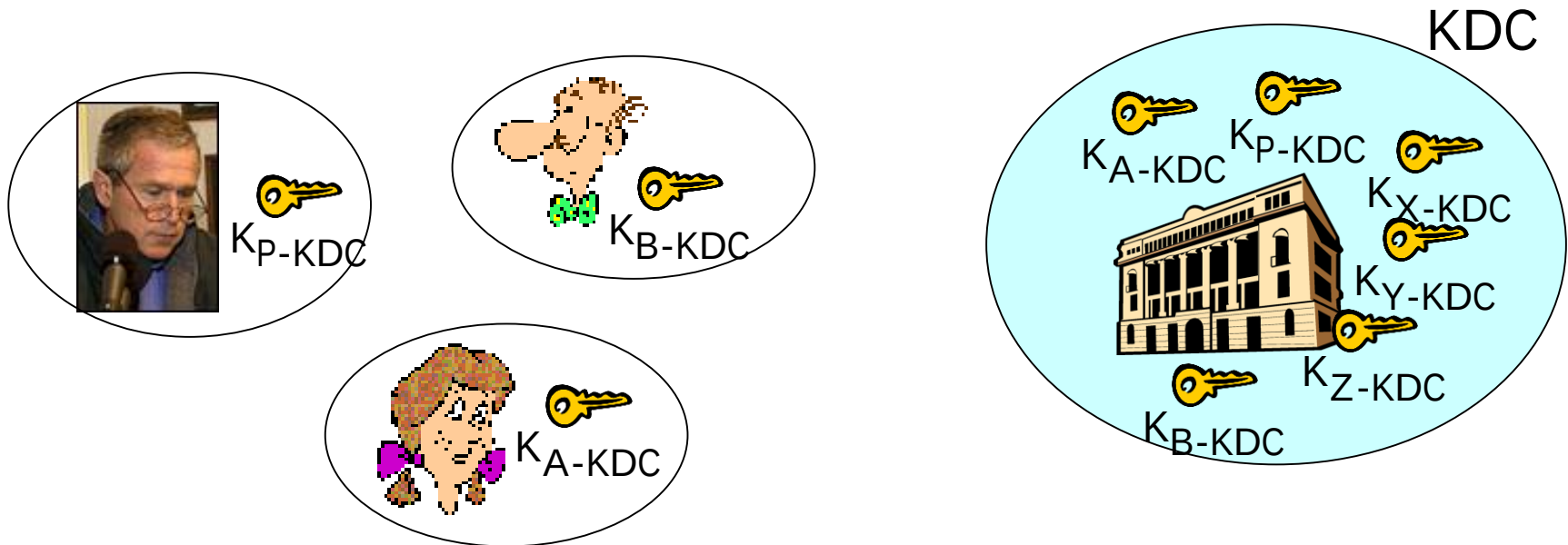
- r When Alice obtains Bob's public key (from web site, e-mail, diskette), how does she know it is Bob's public key, not Trudy's?

Solution:

- r trusted certification authority (CA)

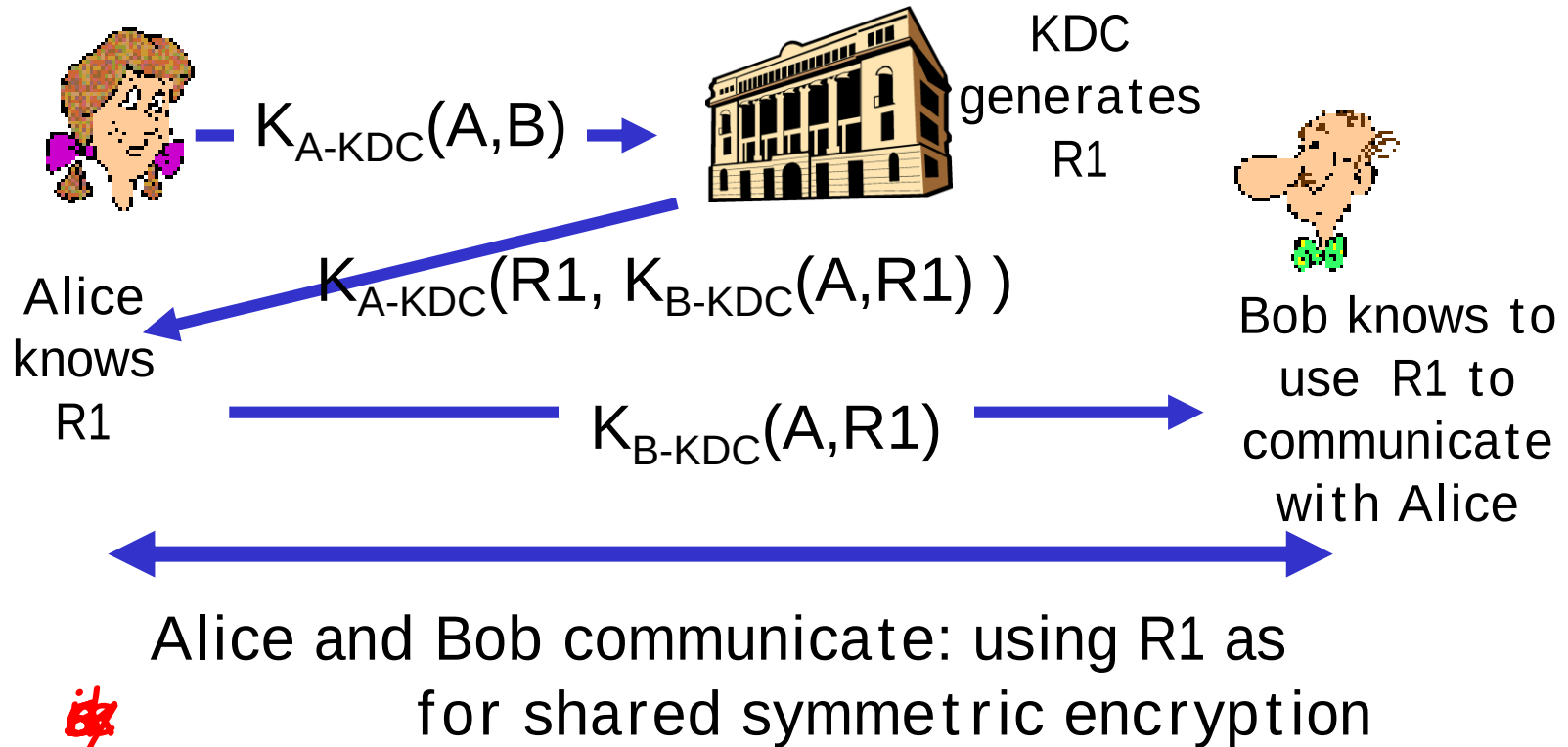
Key Distribution Center (KDC)

- r Alice, Bob need shared symmetric key.
- r **KDC**: server shares different secret key with a registered user (many users)
- r Alice, Bob know own symmetric keys, K_{A-KDC} K_{B-KDC} , for communicating with KDC.



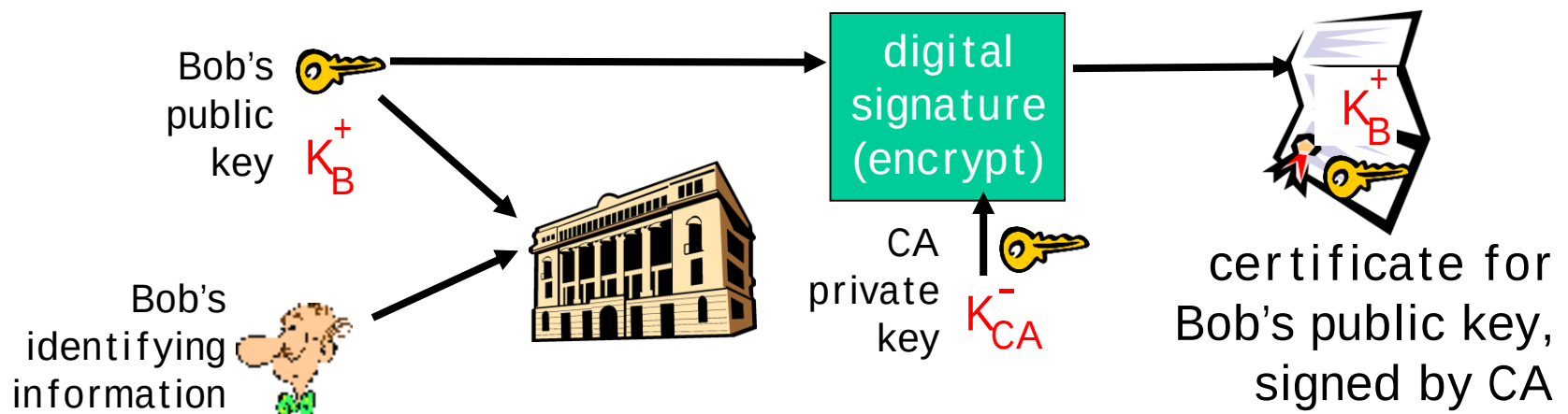
Key Distribution Center (KDC)

Q How does KDC allow Bob, Alice to determine shared symmetric secret key to communicate with each other?



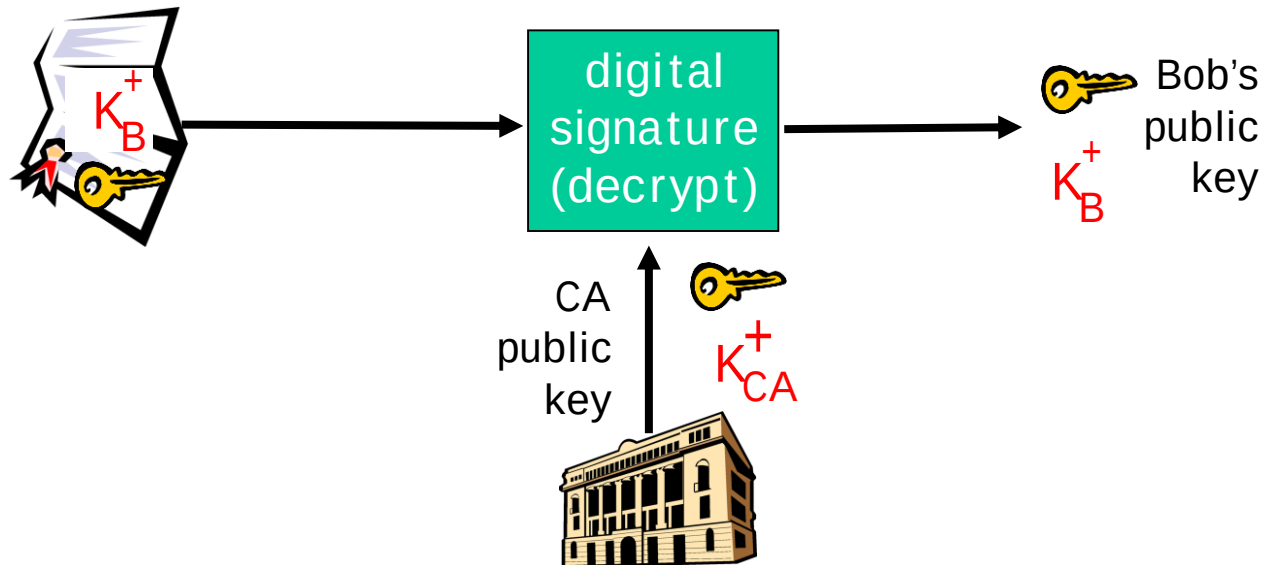
Certification Authorities

- r **Certification authority (CA):** binds public key to particular entity, E.
- r E (person, router) registers its public key with CA.
 - m E provides “proof of identity” to CA.
 - m CA creates certificate binding E to its public key.
 - m certificate containing E’s public key digitally signed by CA
 - CA says “this is E’s public key”



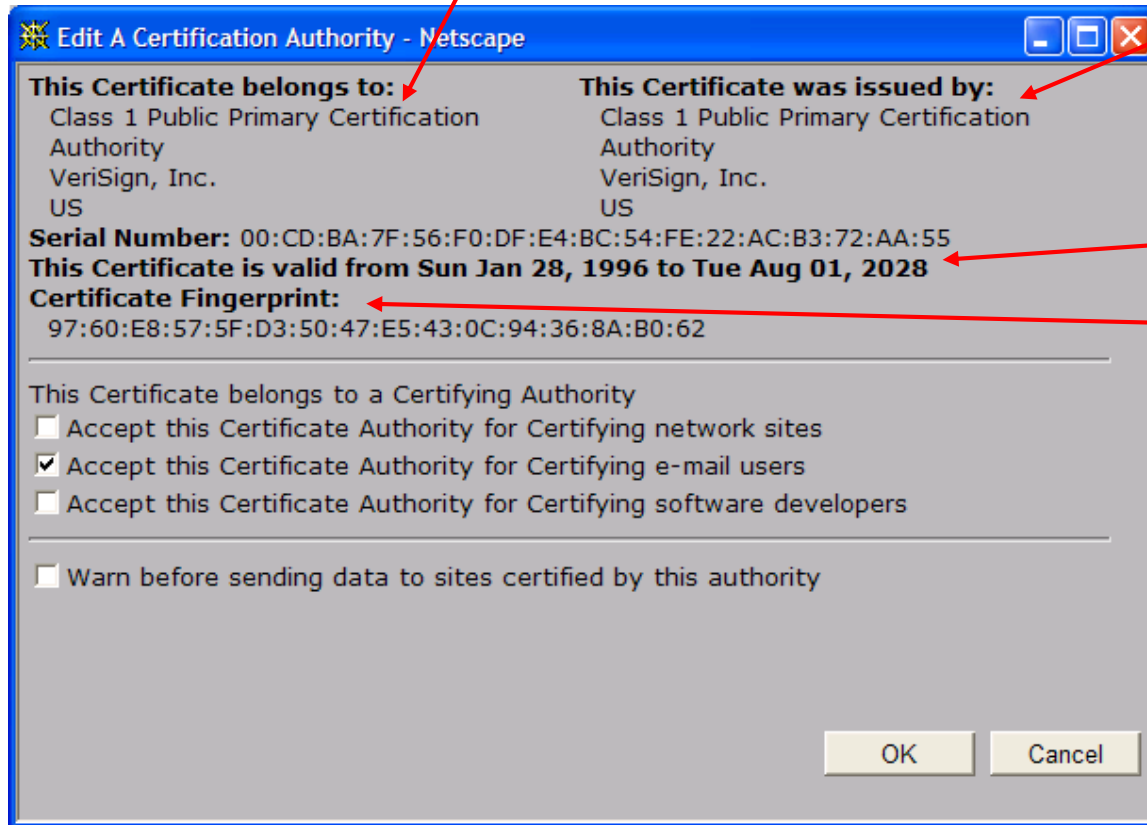
Certification Authorities

- r When Alice wants Bob's public key:
 - m gets Bob's certificate (Bob or elsewhere).
 - m apply CA's public key to Bob's certificate, get Bob's public key



A certificate contains:

- r Serial number (unique to issuer)
- r info about certificate owner, including algorithm and key value itself (not shown)



- r info about certificate issuer
- r valid dates
- r digital signature by issuer

Chapter 8 roadmap

8.1 What is network security?

8.2 Principles of cryptography

8.3 Authentication

8.4 Integrity

8.5 Key Distribution and certification

8.6 Access control: firewalls

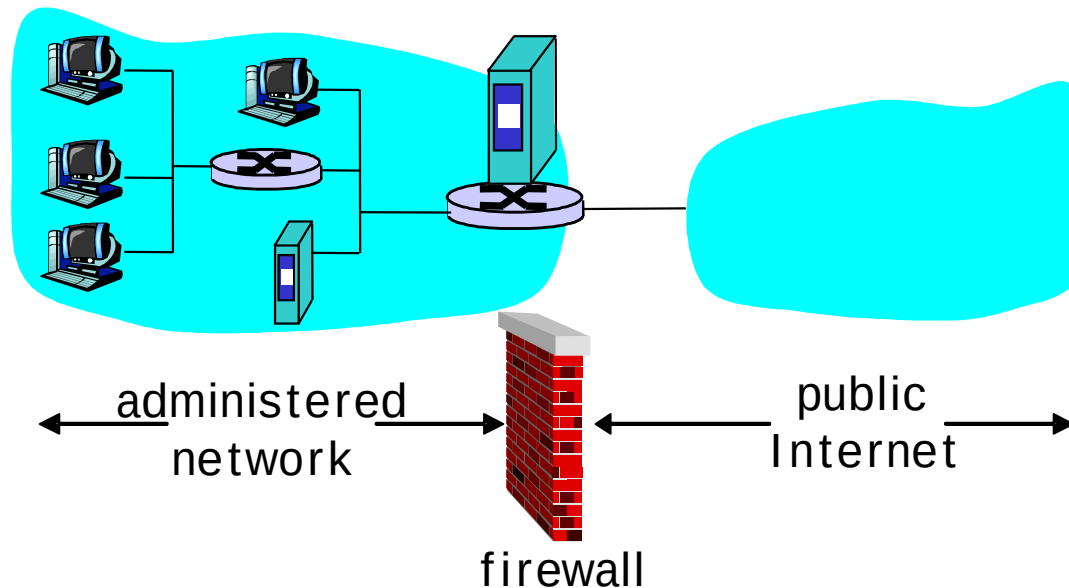
8.7 Attacks and counter measures

8.8 Security in many layers

Firewalls

firewall

isolates organization's internal net from larger Internet, allowing some packets to pass, blocking others.



Firewalls: Why

prevent denial of service attacks:

- m SYN flooding: attacker establishes many bogus TCP connections, no resources left for “real” connections.

prevent illegal modification/access of internal data.

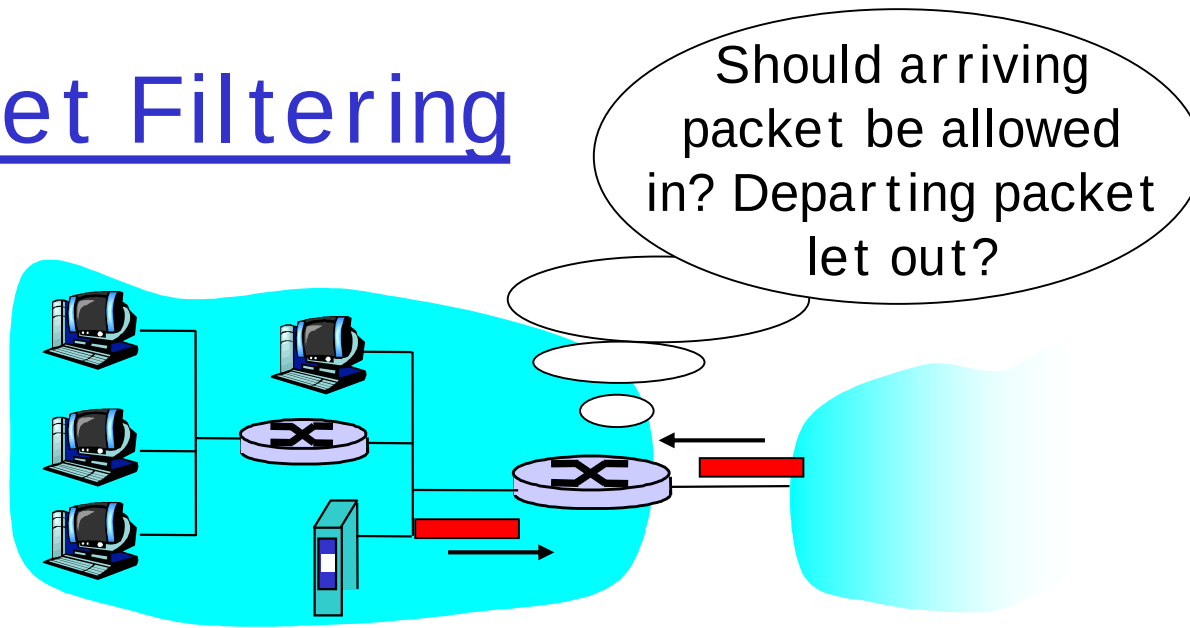
- m e.g., attacker replaces CIA’s homepage with something else

allow only authorized access to inside network (set of authenticated users/hosts)

two types of firewalls:

- m application-level
- m packet-filtering

Packet Filtering



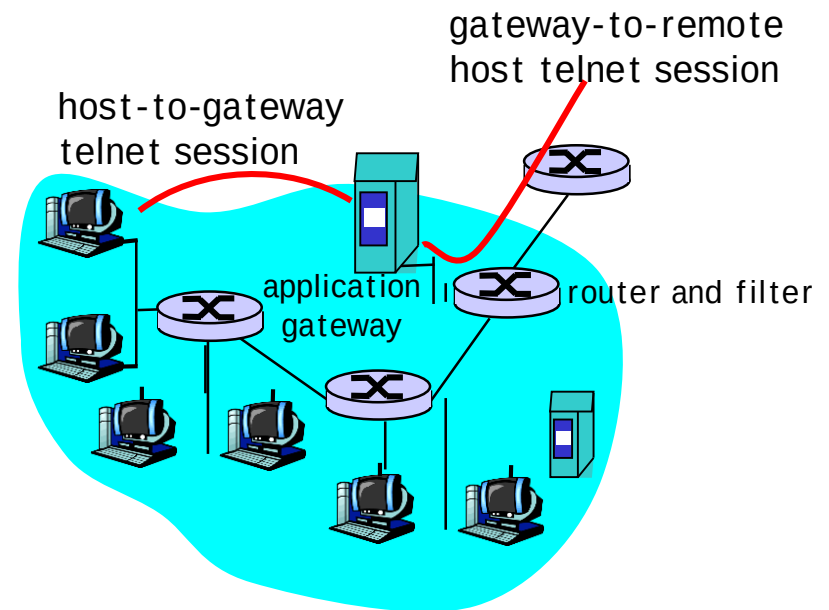
- r internal network connected to Internet via **router firewall**
- r router **filters packet-by-packet**, decision to forward/drop packet based on:
 - m source IP address, destination IP address
 - m TCP/UDP source and destination port numbers
 - m ICMP message type
 - m TCP SYN and ACK bits

Packet Filtering

- r Example 1: block incoming and outgoing datagrams with IP protocol field = 17 and with either source or dest port = 23.
 - m All incoming and outgoing UDP flows and telnet connections are blocked.
- r Example 2: Block inbound TCP segments with ACK=0.
 - m Prevents external clients from making TCP connections with internal clients, but allows internal clients to connect to outside.

Application gateways

- r Filters packets on application data as well as on IP/TCP/UDP fields.
- r Example: allow select internal users to telnet outside.



1. Require all telnet users to telnet through gateway.
2. For authorized users, gateway sets up telnet connection to dest host. Gateway relays data between 2 connections
3. Router filter blocks all telnet connections not originating from gateway.

Limitations of firewalls and gateways

- r IP spoofing: router can't know if data “really” comes from claimed source
- r if multiple app's. need special treatment, each has own app. gateway.
- r client software must know how to contact gateway.
 - m e.g., must set IP address of proxy in Web browser
- r filters often use all or nothing policy for UDP.
- r tradeoff: **degree of communication with outside world, level of security**
- r many highly protected sites still suffer from attacks.

Chapter 8 roadmap

8.1 What is network security?

8.2 Principles of cryptography

8.3 Authentication

8.4 Integrity

8.5 Key Distribution and certification

8.6 Access control: firewalls

8.7 Attacks and counter measures

8.8 Security in many layers

Internet security threats

Mapping:

- m before attacking: “case the joint” – find out what services are implemented on network
- m Use `ping` to determine what hosts have addresses on network
- m Port-scanning: try to establish TCP connection to each port in sequence (see what happens)
- m `nmap` (<http://www.insecure.org/nmap/>) mapper: “network exploration and security auditing”

Countermeasures?

Internet security threats

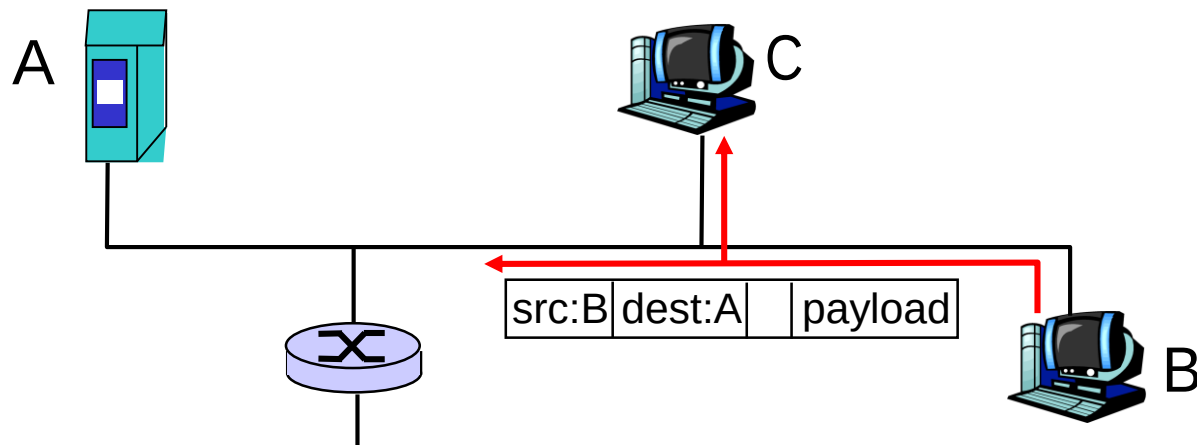
Mapping: countermeasures

- m record traffic entering network
- m look for suspicious activity (IP addresses, ports being scanned sequentially)

Internet security threats

Packet sniffing:

- m broadcast media
- m promiscuous NIC reads all packets passing by
- m can read all unencrypted data (e.g. passwords)
- m e.g.: C sniffs B's packets

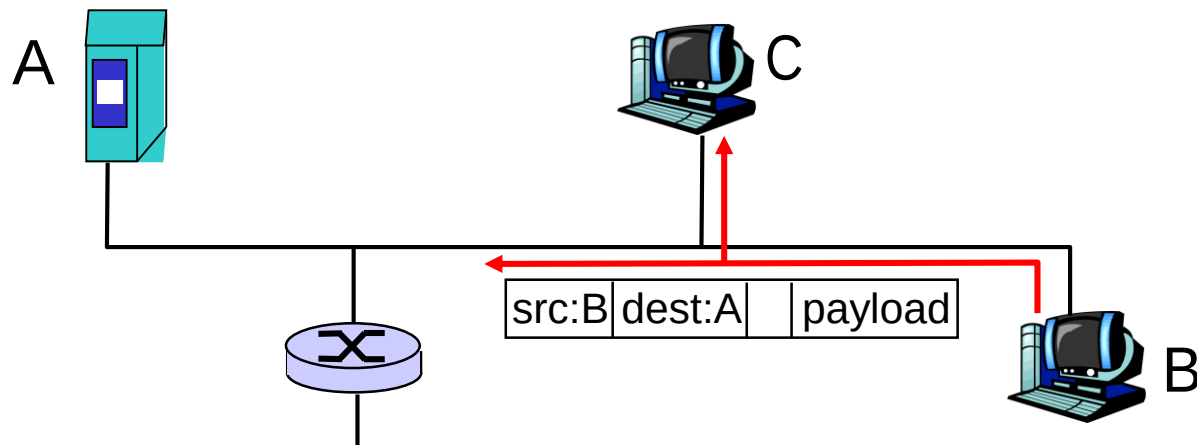


Countermeasures?

Internet security threats

Packet sniffing: countermeasures

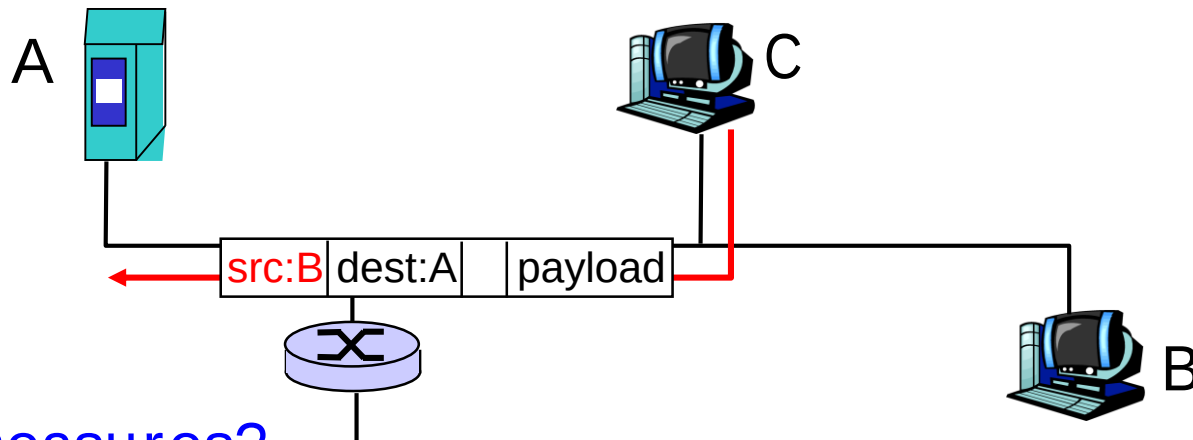
- m all hosts in organization run software that checks periodically if host interface in promiscuous mode.
- m one host per segment of broadcast media (switched Ethernet at hub)



Internet security threats

IP Spoofing:

- m can generate “raw” IP packets directly from application, putting any value into IP source address field
- m receiver can't tell if source is spoofed
- m e.g.: C pretends to be B

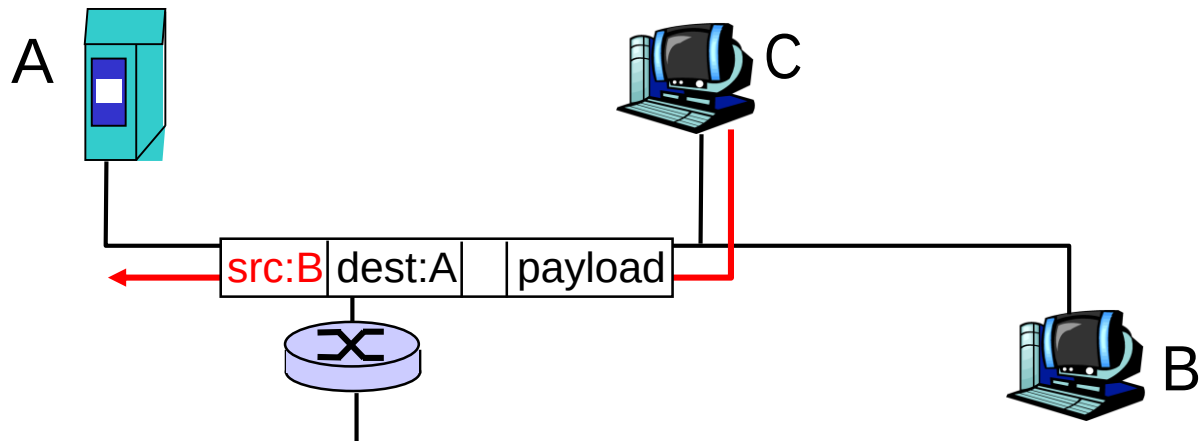


Countermeasures?

Internet security threats

IP Spoofing: ingress filtering

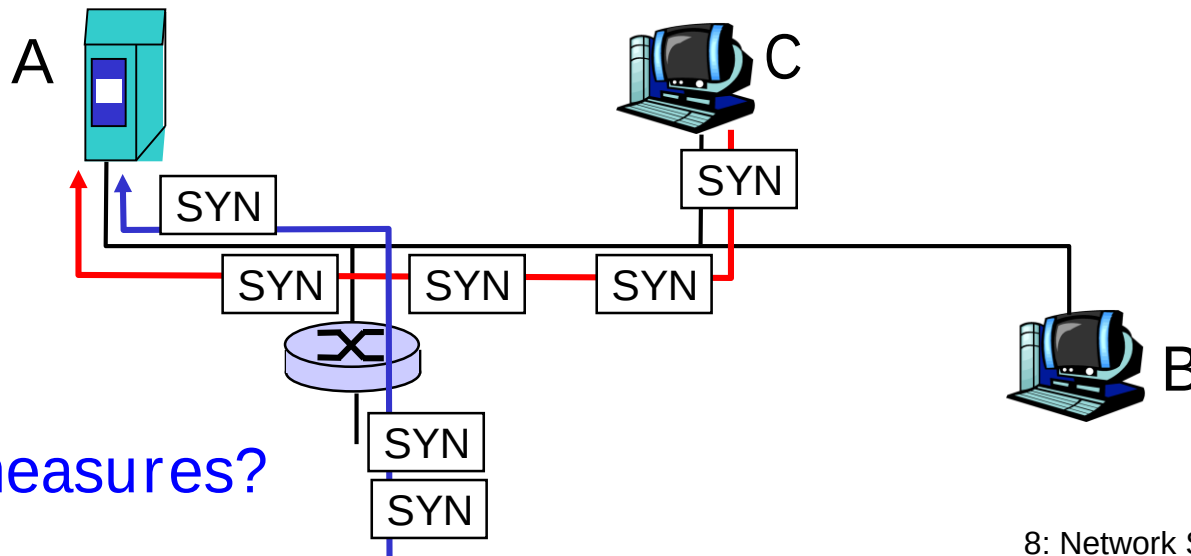
- m routers should not forward outgoing packets with invalid source addresses (e.g., datagram source address not in router's network)
- m great, but ingress filtering can not be mandated for all networks



Internet security threats

Denial of service (DOS):

- m flood of maliciously generated packets “swamp” receiver
- m Distributed DOS (DDOS): multiple coordinated sources swamp receiver
- m e.g., C and remote host SYN-attack A

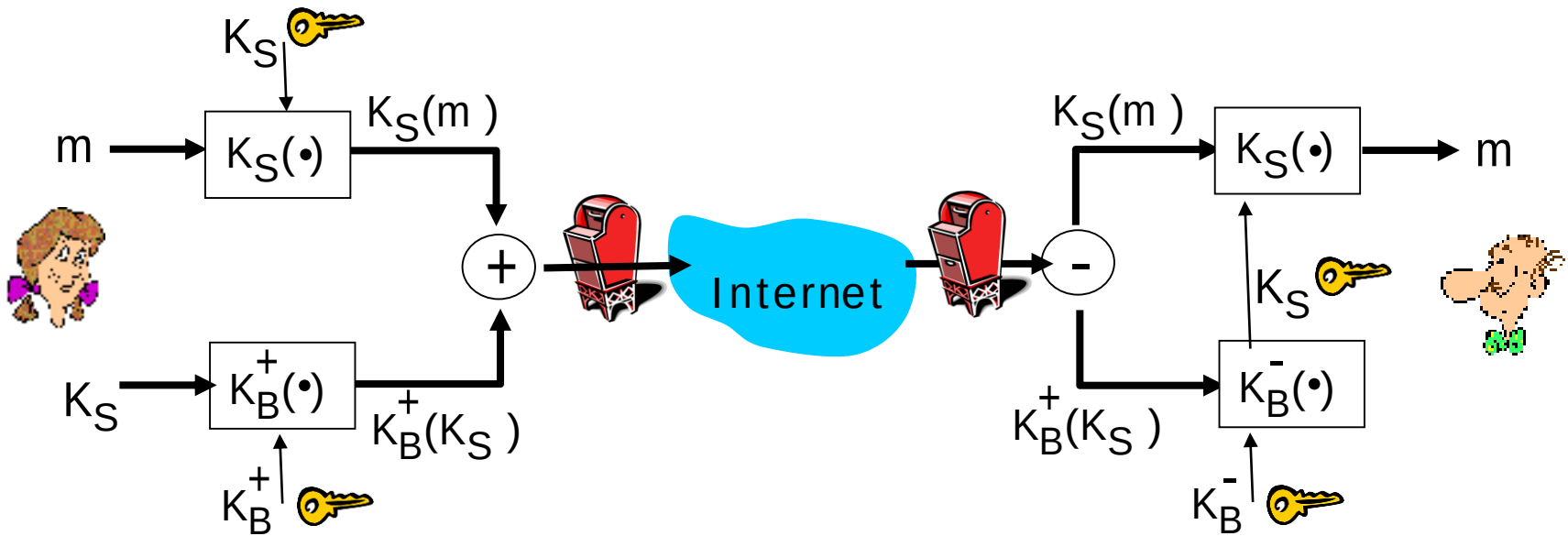


Chapter 8 roadmap

- 8.1 What is network security?
- 8.2 Principles of cryptography
- 8.3 Authentication
- 8.4 Integrity
- 8.5 Key Distribution and certification
- 8.6 Access control: firewalls
- 8.7 Attacks and counter measures
- 8.8 Security in many layers
 - 8.8.1. Secure email
 - 8.8.2. Secure sockets
 - 8.8.3. IPsec
 - 8.8.4. Security in 802.11

Secure e-mail

Alice wants to send confidential e-mail, m , to Bob.



Alice:

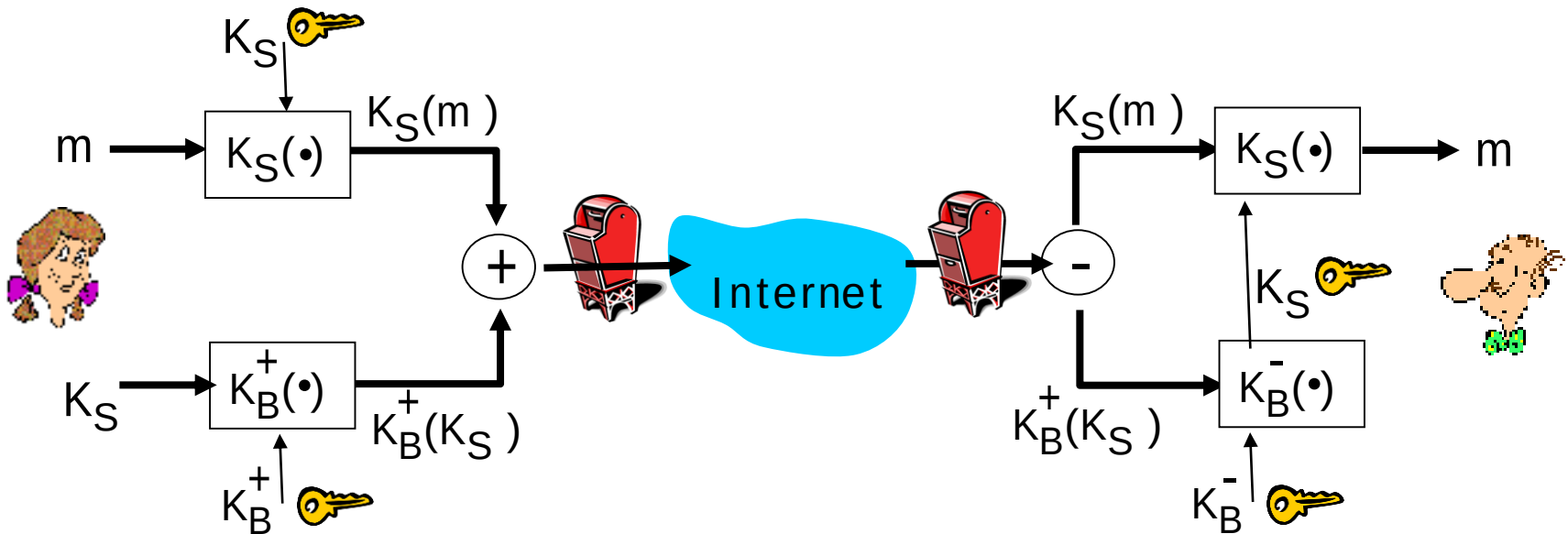
generates random K_S private key,

encrypts message with K_S (for efficiency)
also encrypts K_S with Bob's public key.

sends both $K_S(m)$ and $K_B(K_S)$ to Bob.

Secure e-mail

Alice wants to send confidential e-mail, m , to Bob.



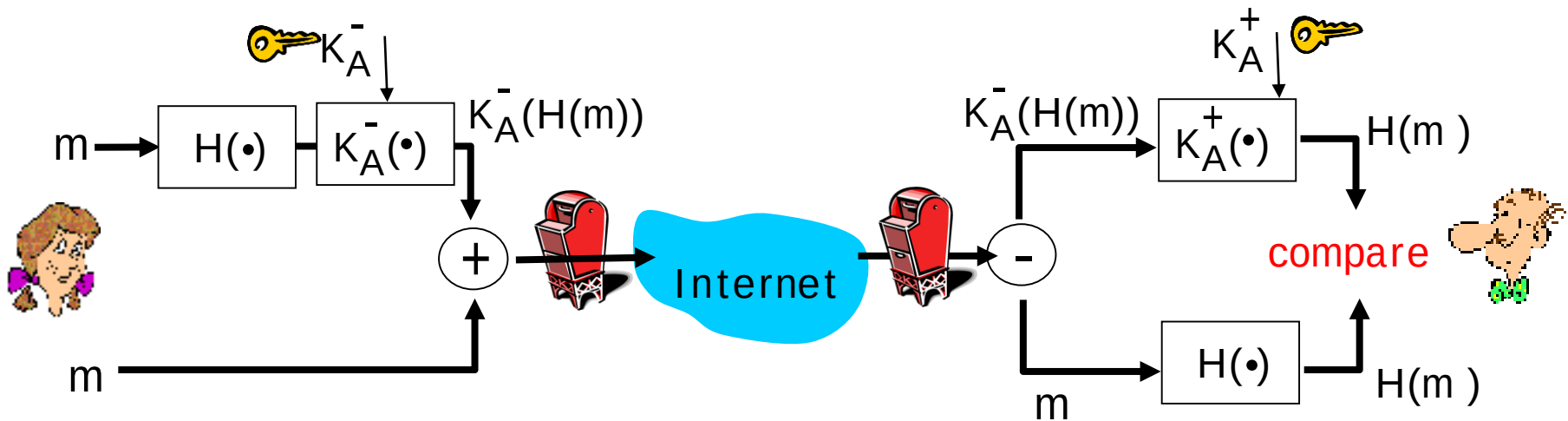
Bob:

uses his private key to decrypt and recover K_S

uses K_S to decrypt $K_S(m)$ to recover m

Secure e-mail (continued)

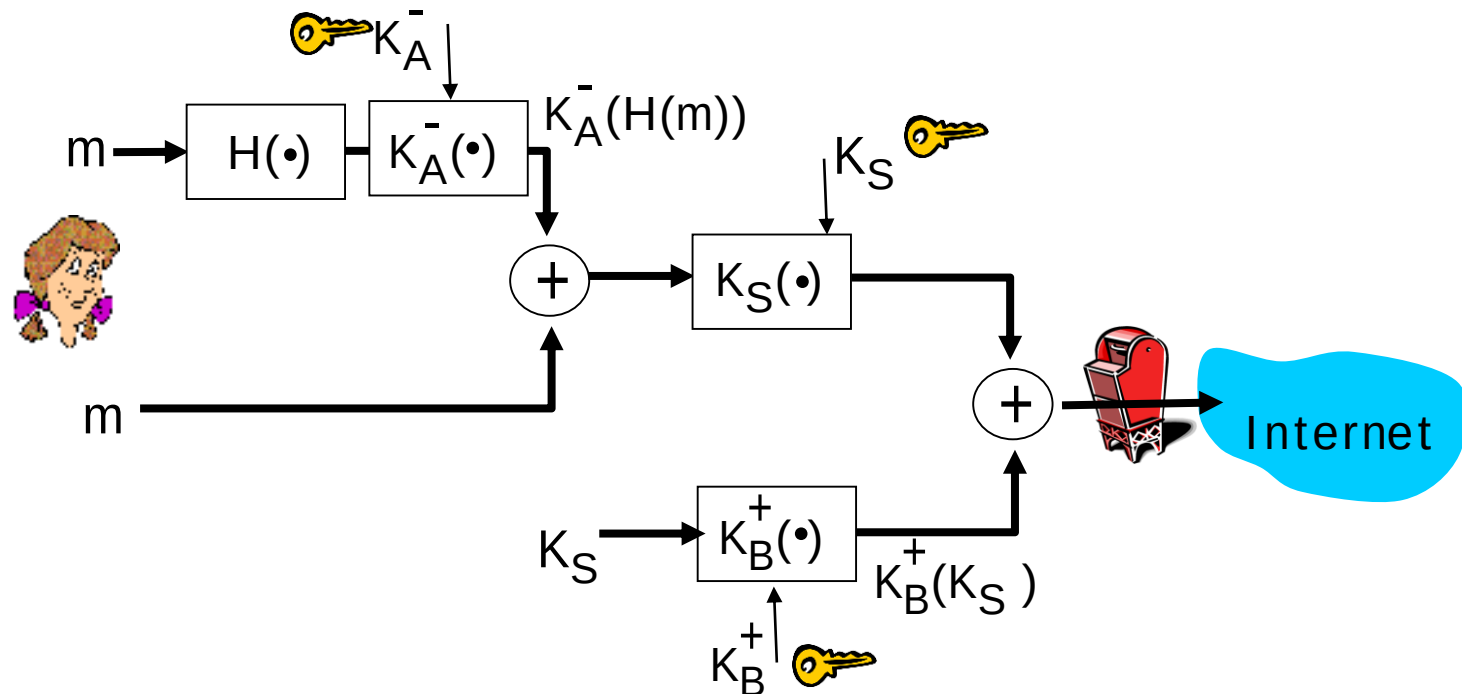
- Alice wants to provide sender authentication and message integrity.



- Alice digitally signs message.
- sends both message (in the clear) and digital signature.

Secure e-mail (continued)

- Alice wants to provide secrecy, sender authentication, message integrity.



Alice uses three keys: her private key, Bob's public key, newly created symmetric key

Pretty good privacy (PGP)

- r Internet e-mail encryption scheme, de-facto standard.
- r uses symmetric key cryptography, public key cryptography, hash function, and digital signature as described.
- r provides secrecy, sender authentication, integrity.
- r inventor, Phil Zimmerman, was target of 3-year federal investigation.

A PGP signed message:

```
---BEGIN PGP SIGNED MESSAGE---  
Hash: SHA1  
  
Bob:My husband is out of town  
    tonight.Passionately yours,  
    Alice  
  
---BEGIN PGP SIGNATURE---  
Version: PGP 5.0  
Charset: noconv  
yhHJRHhGJGhgg/12EpJ+lo8gE4vB3mqJ  
    hFEvZP9t6n7G6m5Gw2  
---END PGP SIGNATURE---
```

Secure sockets layer (SSL)

- r transport layer security to any TCP-based app using SSL services.
- r used between Web browsers, servers for e-commerce (shttp).
- r security services:
 - m server authentication
 - m data encryption
 - m client authentication (optional)

- r server authentication:
 - m SSL-enabled browser includes public keys for trusted CAs.
 - m Browser requests server certificate, issued by trusted CA.
 - m Browser uses CA's public key to extract server's public key from certificate.
- r check your browser's security menu to see its trusted CAs.

SSL (continued)

Encrypted SSL session:

- r Browser generates ~~key~~, encrypts it with server's public key, sends encrypted key to server.
- r Using private key, server decrypts session key.
- r Browser, server know session key
 - m All data sent into TCP socket (by client or server) encrypted with session key.
- r SSL: basis of IETF Transport Layer Security (TLS).
- r SSL can be used for non-Web applications, e.g., IMAP.
- r Client authentication can be done with client certificates.

IPsec: Network Layer Security

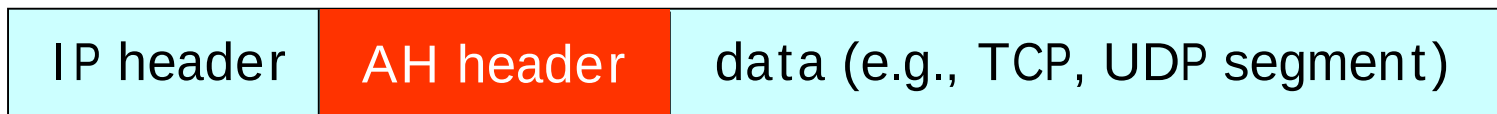
- r **Network-layer secrecy:**
 - m sending host encrypts the data in IP datagram
 - m TCP and UDP segments; ICMP and SNMP messages.
- r **Network-layer authentication**
 - m destination host can authenticate source IP address
- r **Two principle protocols:**
 - m authentication header (AH) protocol
 - m encapsulation security payload (ESP) protocol
- r **For both AH and ESP, source, destination handshake:**
 - m create network-layer logical channel called a security association (SA)
- r **Each SA unidirectional.**
- r **Uniquely determined by:**
 - m security protocol (AH or ESP)
 - m source IP address
 - m 32-bit connection ID

Authentication Header (AH) Protocol

- r provides source authentication, data integrity, no confidentiality
- r AH header inserted between IP header, data field.
- r protocol field: 51
- r intermediate routers process datagrams as usual

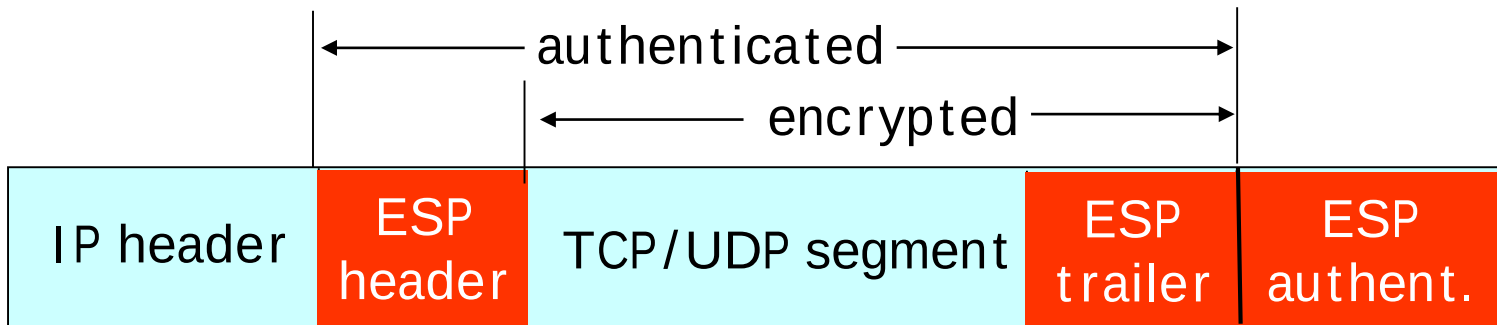
AH header includes:

- r connection identifier
- r authentication data:
source- signed message
digest calculated over
original IP datagram.
- r next header field:
specifies type of data
(e.g., TCP, UDP, ICMP)



ESP Protocol

- r provides secrecy, host authentication, data integrity.
- r data, ESP trailer encrypted.
- r next header field is in ESP trailer.
- r ESP authentication field is similar to AH authentication field.
- r Protocol = 50.



IEEE 802.11 security

- r ~~W~~ -~~g~~ drive around Bay area, see what 802.11 networks available?
 - m More than 9000 accessible from public roadways
 - m 85% use no encryption/authentication
 - m packet-sniffing and various attacks easy!
- r **Securing 802.11**
 - m encryption, authentication
 - m first attempt at 802.11 security: Wired Equivalent Privacy (WEP): a failure
 - m current attempt: 802.11i

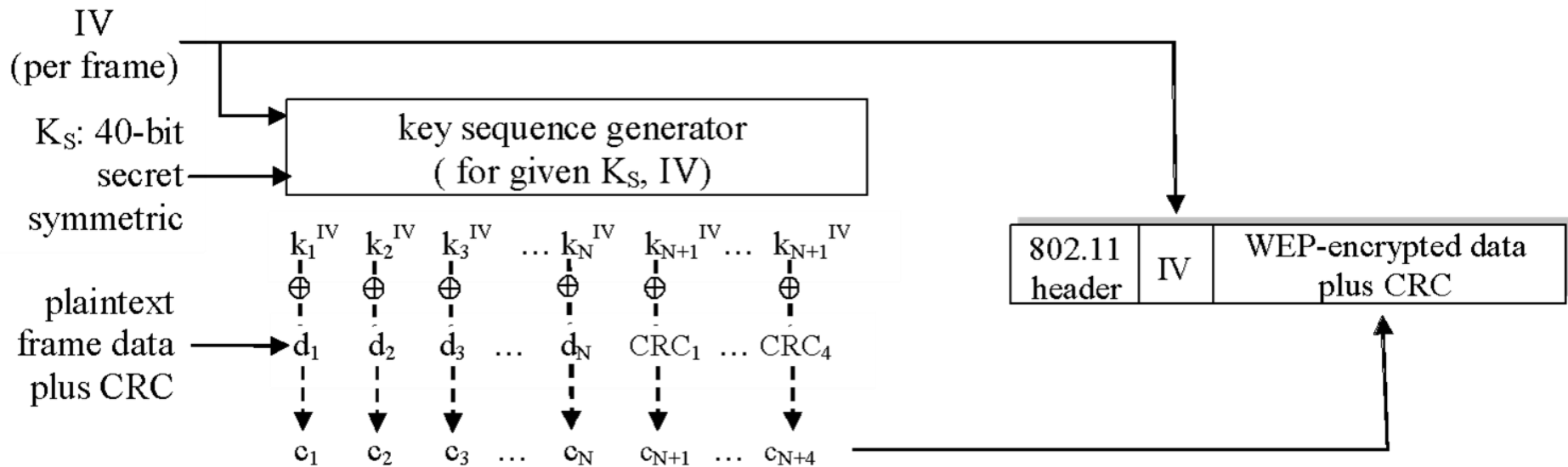
Wired Equivalent Privacy (WEP):

- r authentication as in protocol ~~A~~
 - m host requests authentication from access point
 - m access point sends 128 bit nonce
 - m host encrypts nonce using shared symmetric key
 - m access point decrypts nonce, authenticates host
- r no key distribution mechanism
- r authentication: knowing the shared key is enough

WEP data encryption

- r Host / AP share 40 bit symmetric key (semi-permanent)
- r Host appends 24-bit initialization vector (IV) to create 64-bit key
- r 64 bit key used to generate stream of keys, k_i^{IV}
- r k_i^{IV} used to encrypt ith byte, d_i , in frame:
$$c_i = d_i \text{ XOR } k_i^{\text{IV}}$$
- r IV and encrypted bytes, c_i sent in frame

802.11 WEP encryption



Sender-side WEP encryption

Breaking 802.11 WEP encryption

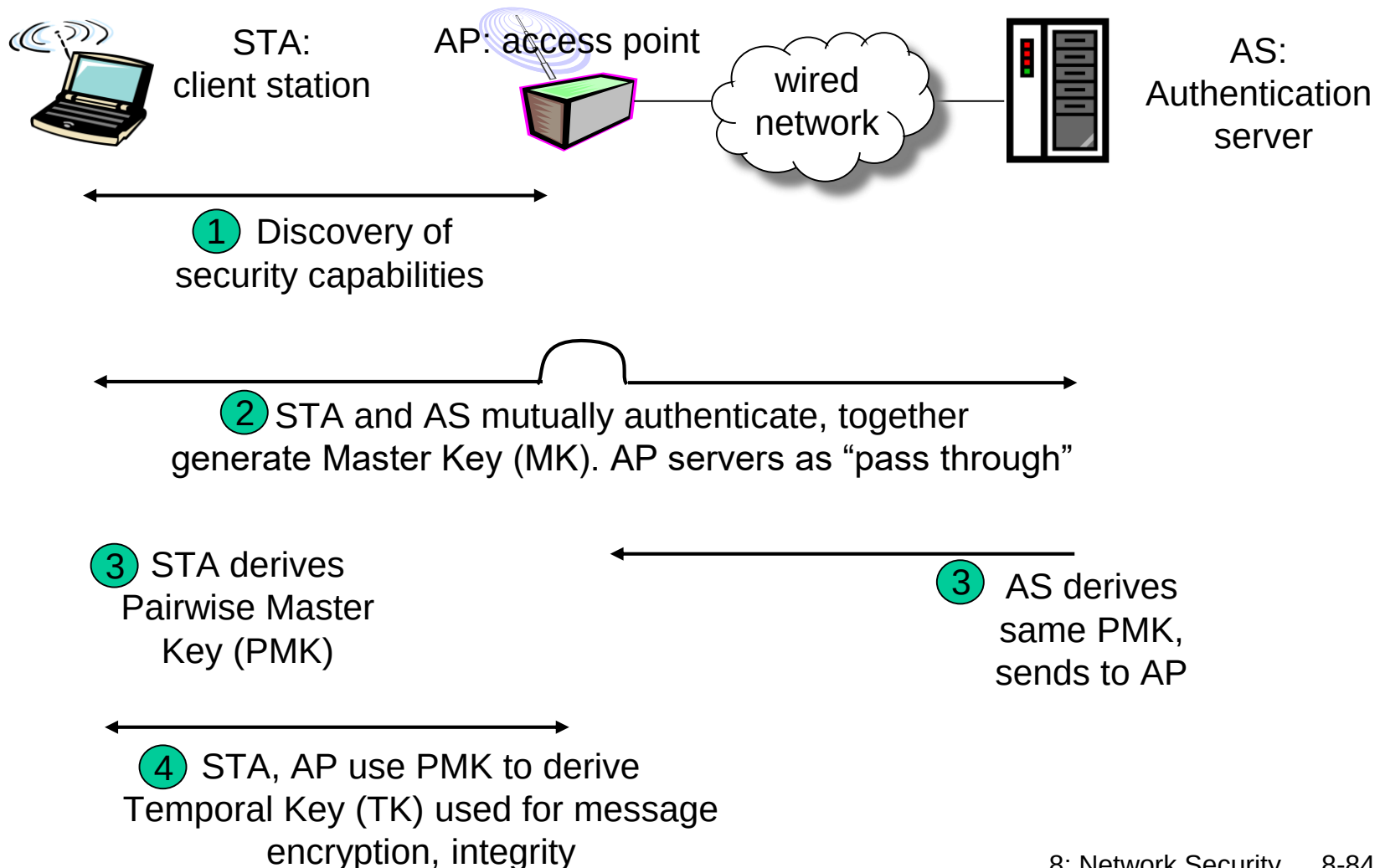
Security hole:

- r 24-bit IV, one IV per frame, -> IV's eventually reused
- r IV transmitted in plaintext -> IV reuse detected
- r **Attack:**
 - m Trudy causes Alice to encrypt known plaintext $d_1 d_2 d_3 d_4 \dots$
 - m Trudy sees: $c_i = d_i \text{ XOR } k_i^{\text{IV}}$
 - m Trudy knows $c_i d_i$, so can compute k_i^{IV}
 - m Trudy knows encrypting key sequence $k_1^{\text{IV}} k_2^{\text{IV}} k_3^{\text{IV}} \dots$
 - m Next time IV is used, Trudy can decrypt!

802.11i: improved security

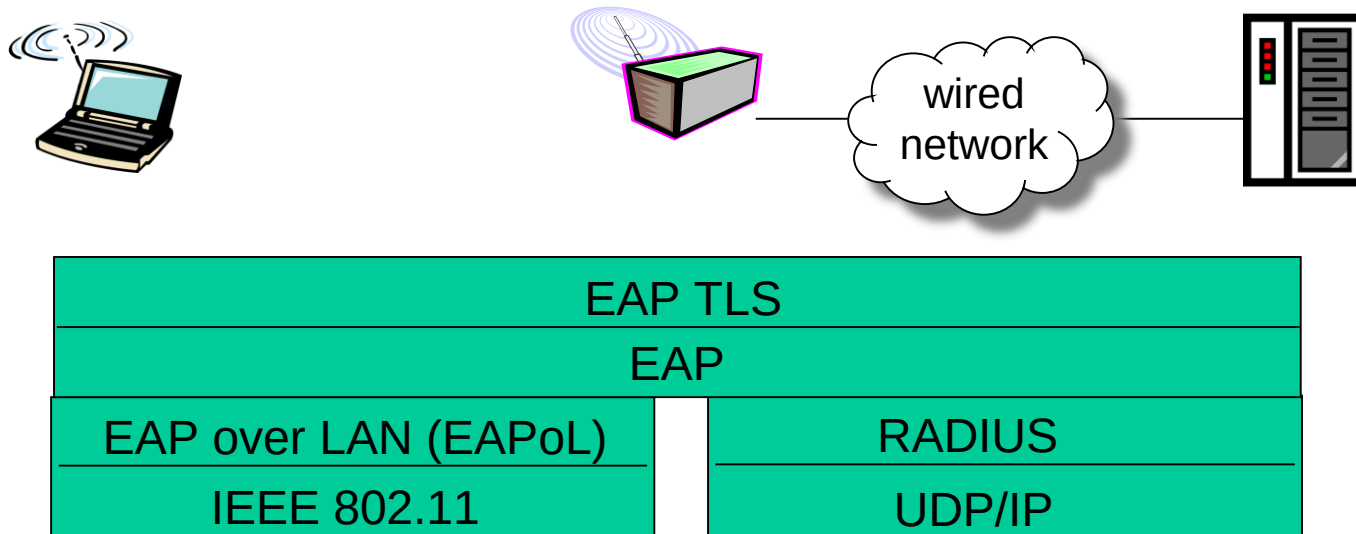
- r numerous (stronger) forms of encryption possible
- r provides key distribution
- r uses authentication server separate from access point

802.11i: four phases of operation



EAP: extensible authentication protocol

- r EAP: end-end client (mobile) to authentication server protocol
- r EAP sent over separate “links”
 - m mobile-to-AP (EAP over LAN)
 - m AP to authentication server (RADIUS over UDP)



Network Security (summary)

Basic techniques.....

- m cryptography (symmetric and public)
- m authentication
- m message integrity
- m key distribution

.... used in many different security scenarios

- m secure email
- m secure transport (SSL)
- m IP sec
- m 802.11